ĐẠI HỌC QUỐC GIA HÀ NỘI

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO DỰ ÁN CÔNG NGHỆ

PHÁT HIỆN VÀ PHÂN TÍCH NGUY CƠ LỪA ĐẢO TRỰC TUYẾN BẰNG HỌC MÁY, LLM VÀ RAG

(Phishing Detection and Analysis
using Machine Learning, LLMs and RAG)

Sinh viên thực hiện: Lê Văn Khoa

Mã sinh viên: 23020092

Lớp: K68I-IT2

Giảng viên hướng dẫn: ThS. Trần Ngọc Trúc Linh

Hà Nội, tháng 10 năm 2026

THÔNG TIN VỀ BẢN BÁO CÁO

Báo cáo ghi nhận hiện trạng dự án và các kết quả có thể kiểm chứng đến ngày 26/10/2026. Cấu trúc được tham khảo từ mẫu học phần Dự án công nghệ và đề cương của sinh viên; nội dung được cập nhật theo mã nguồn, tệp cấu hình và kết quả thực nghiệm đang lưu trong dự án.

Các mục được ghi “đã triển khai” hoặc “đã đo” có bằng chứng cài đặt hay kết quả tương ứng. Các mục được ghi “thiết kế”, “mục tiêu” hoặc “kế hoạch” chưa được coi là tính năng hay kết quả đã hoàn thành. Riêng RAG đã có kho tài liệu, chưa có embedding, chỉ mục, truy xuất hoặc số đo tác động trong luồng ứng dụng.

Công cụ AI được sử dụng để hỗ trợ rà soát mã nguồn, thu thập tài liệu, xây dựng công cụ đánh giá và biên soạn bản thảo. Sinh viên cần đọc, kiểm chứng và chịu trách nhiệm về bản nộp, đồng thời bổ sung những thay đổi phát sinh sau mốc cập nhật. Bản này không thay cho lời cam đoan và chữ ký xác nhận của sinh viên.

TÓM TẮT

Đề tài xây dựng PhishLens, một ứng dụng hỗ trợ kiểm tra nguy cơ lừa đảo trong URL, email và tin nhắn tiếng Việt. Hệ thống kết hợp mô hình phân loại URL dựa trên đặc trưng chuỗi với mô hình ngôn ngữ lớn để phân tích hành động được yêu cầu và giải thích kết quả. Phần mở rộng RAG hướng tới bổ sung kiến thức cảnh báo và quy trình hợp lệ có nguồn đối chiếu.

Bản hiện tại sử dụng XGBoost với 21 đặc trưng URL, DeepSeek-V4-Flash qua API FPT và giao diện web cục bộ. Trên 8.941 URL kiểm tra PhishVN, ngưỡng cảnh báo đạt Precision 81,83%, Recall 99,39%, F1 89,76% và tỷ lệ báo nhầm 29,26%. Trên mẫu cân bằng 100 URL, nhận định LLM khi được cung cấp kết quả URL đạt F1 90,09%, so với 63,16% của LLM độc lập; tuy nhiên tỷ lệ báo nhầm tăng từ 4% lên 22%. Quy tắc kết hợp hiện hành đưa F1 đầu ra cuối về 88,50%, cho thấy thêm thành phần chưa đồng nghĩa với kết quả cuối tốt hơn.

Dự án đã chuẩn bị 25 bản tóm lược tiếng Việt có dẫn nguồn từ 11 đơn vị và có 60 ca kiểm thử tự động đạt. Các kết quả hiện tại chủ yếu phản ánh tác vụ URL; chưa chứng minh hiệu quả trên email thực tế hoặc tác dụng của RAG. Công việc tiếp theo tập trung vào truy xuất quy mô nhỏ, tập thông điệp được gán nhãn độc lập, kiểm tra nguồn dẫn và giảm báo nhầm mà không che giấu các trường hợp thiếu thông tin.

Từ khóa: phishing; PhishVN; XGBoost; mô hình ngôn ngữ lớn; RAG.

MỤC LỤC

CHƯƠNG 1. GIỚI THIỆU....1
1.1. Bối cảnh và lý do chọn đề tài....1
1.2. Mục tiêu của đề tài....1
1.3. Phạm vi và đối tượng....2
1.4. Đóng góp và điểm nổi bật....2
1.5. Tiêu chí hoàn thành và trạng thái....2
1.6. Cấu trúc báo cáo....3
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ....4
2.1. Bài toán nhận diện nguy cơ....4
2.2. Học máy từ đặc trưng URL....4
2.3. LLM, bằng chứng và RAG....4
2.4. Các giải pháp và công trình liên quan....5
2.5. Công nghệ sử dụng và lý do lựa chọn....6
CHƯƠNG 3. PHÂN TÍCH YÊU CẦU VÀ BÀI TOÁN....7
3.1. Phát biểu bài toán và câu hỏi nghiên cứu....7
3.2. Yêu cầu chức năng....7
3.3. Yêu cầu phi chức năng....8
3.4. Đặc tả các chức năng chính....9
3.5. Mức cảnh báo và quy tắc kết hợp hiện hành....10
CHƯƠNG 4. THIẾT KẾ GIẢI PHÁP....12
4.1. Kiến trúc tổng thể....12
4.2. Cấu trúc dữ liệu và bằng chứng....12
4.3. Dữ liệu và pipeline mô hình URL....13
4.4. LLM và kiểm tra đầu ra....15
4.5. Kho tài liệu RAG và thiết kế truy xuất....15
4.6. Thiết kế API và giao diện....18
4.7. Bảo vệ dữ liệu và prompt injection....18
CHƯƠNG 5. CÀI ĐẶT VÀ TRIỂN KHAI....19
5.1. Môi trường và tài nguyên....19
5.2. Tổ chức mã nguồn....19
5.3. Hiện thực và giao diện các chức năng chính....20
5.4. Kết nối LLM và ngân sách....22
5.5. Triển khai và cấu hình vận hành....23
CHƯƠNG 6. THỰC NGHIỆM VÀ ĐÁNH GIÁ....24
6.1. Thiết kế đánh giá và cách tính chỉ số....24
6.2. Kiểm thử phần mềm và các lỗi còn tồn tại....25
6.3. Kết quả mô hình URL trên PhishVN....26
6.4. So sánh có và không cung cấp kết quả URL cho LLM....27
6.5. Bộ chẩn đoán mô phỏng và so sánh baseline....28
6.6. Thời gian phản hồi và khả năng tái lập....29
6.7. Kế hoạch đánh giá LLM + RAG chưa thực hiện....29
6.8. Thảo luận và giới hạn diễn giải....32

CHƯƠNG 7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN....33
7.1. Kết quả đạt được....33
7.2. Hạn chế....33
7.3. Kế hoạch hoàn thiện trong tám tuần....33
7.4. Bài học và định hướng tiếp theo....34
TÀI LIỆU THAM KHẢO....35
PHỤ LỤC A. CÀI ĐẶT VÀ SỬ DỤNG....37
A.1. Chuẩn bị và cài đặt....37
A.2. Cấu hình và chạy....37
A.3. Thao tác kiểm tra và xử lý lỗi....38
A.4. Kiểm thử và tái lập kết quả đã có....38
PHỤ LỤC B. DANH MỤC 25 NGUỒN RAG....39
PHỤ LỤC C. BẢN ĐỒ BẰNG CHỨNG VÀ QUY ƯỚC....43
C.1. Hiện vật để kiểm tra số liệu....43
C.2. Khóa định danh của lần thực nghiệm....44
C.3. Phân biệt kết quả, mục tiêu và điều chưa biết....44

DANH MỤC HÌNH VẼ VÀ BẢNG BIỂU

Danh mục hình vẽ

Hình 3.1. Các tương tác chính với ứng dụng; nét đứt là phần chưa tích hợp · 8
Hình 4.1. Kiến trúc baseline và vị trí bổ sung RAG · 12
Hình 4.2. Thiết kế luồng RAG; chưa triển khai trong runtime · 17
Hình 5.1. Giao diện baseline chạy thực tế trên máy cục bộ · 20
Hình 5.2. Bản xem trước đã che thông tin bằng quy tắc · 21
Hình 5.3. Kết quả ML thực trên một đầu vào minh họa, không gọi LLM · 22
Hình 6.1. Đánh đổi giữa độ nhạy và báo nhầm trên cùng tập URL test · 26

Danh mục bảng biểu

Bảng 1.1. Tiêu chí hoàn thành và bằng chứng hiện tại · 3
Bảng 2.1. Đối chiếu dịch vụ và công trình liên quan · 5
Bảng 2.2. Công nghệ và vai trò trong hệ thống · 6
Bảng 3.1. Yêu cầu chức năng và hiện trạng · 7
Bảng 3.2. Yêu cầu phi chức năng và cách xác minh · 9
Bảng 3.3. Quy tắc fusion của baseline đang chạy · 10
Bảng 4.1. Các cấu trúc dữ liệu chính · 13
Bảng 4.2. Thành phần các split PhishVN được dùng · 13
Bảng 4.3. Cơ cấu kho tài liệu RAG ban đầu · 16
Bảng 4.4. API baseline · 18
Bảng 5.1. Tổ chức mã nguồn và hiện vật · 19
Bảng 6.1. Các tầng đánh giá và phạm vi kết luận · 24
Bảng 6.2. Kiểm thử tiêu biểu và truy vết yêu cầu · 25
Bảng 6.3. Chỉ số URL trên toàn bộ test tại các ngưỡng đã khóa · 26
Bảng 6.4. Ma trận nhầm lẫn dưới dạng số đếm · 26
Bảng 6.5. Báo nhầm tại WARNING theo nguồn benign · 27
Bảng 6.6. Kết quả trên cùng 100 URL test cân bằng · 28
Bảng 6.7. Thiết kế so sánh tác dụng ML và RAG · 30
Bảng 6.8. Rubric chấm lời giải thích dự kiến, mỗi tiêu chí 0–2 điểm · 31
Bảng 7.1. Kế hoạch thu gọn phạm vi và đầu ra nghiệm thu · 34

DANH MỤC TỪ VIẾT TẮT

Các thuật ngữ dùng trong báo cáo

Viết tắt	Tiếng Anh	Diễn giải
API	Application Programming Interface	Giao diện lập trình ứng dụng
LLM	Large Language Model	Mô hình ngôn ngữ lớn
RAG	Retrieval-Augmented Generation	Sinh nội dung có bổ sung tài liệu truy xuất
ML	Machine Learning	Học máy
URL	Uniform Resource Locator	Địa chỉ tài nguyên
OTP	One-Time Password	Mã xác thực dùng một lần
FPR	False Positive Rate	Tỷ lệ báo nhầm trên lớp âm
TP / FP	True / False Positive	Cảnh báo đúng / cảnh báo nhầm
TN / FN	True / False Negative	Âm đúng / bỏ sót
PII	Personally Identifiable Information	Thông tin nhận dạng cá nhân
p95	95th percentile	Phân vị 95 của thời gian đo
UNKNOWN	Abstention / insufficient evidence	Chưa đủ thông tin để kết luận

CHƯƠNG 1. GIỚI THIỆU

1.1. Bối cảnh và lý do chọn đề tài

Một thông báo về tài khoản sắp bị khóa, khoản học bổng cần xác nhận hoặc đơn hàng cần hoàn tiền có thể khiến người nhận vội làm theo. Điểm nguy hiểm thường nằm ở hành động mà người gửi yêu cầu: cung cấp mật khẩu, gửi OTP, cài ứng dụng hoặc chuyển tiền. Một tin nhắn không có đường dẫn vẫn có thể dẫn dụ người nhận; một thông báo hợp lệ cũng có thể nhắc đến OTP để khuyến cáo không chia sẻ mã.

Báo Điện tử Chính phủ ngày 07/01/2026 dẫn thống kê của Bộ Công an cho biết thiệt hại do lừa đảo trực tuyến trong 11 tháng đầu năm 2025 ước tính trên 6.000 tỷ đồng. Đây là số liệu về lừa đảo trực tuyến nói chung, không phải riêng số vụ phishing qua URL. Số liệu được dùng để đặt bối cảnh, không dùng suy ra tỷ lệ phishing trong đầu vào ứng dụng. [1]

Các dịch vụ kiểm tra đường dẫn cung cấp căn cứ bổ sung. Google Safe Browsing đối chiếu URL với danh sách tài nguyên nguy hiểm được cập nhật; VirusTotal tổng hợp thông tin từ nhiều công cụ phân tích. Trong phạm vi đề tài, nhu cầu còn lại là giải thích bằng tiếng Việt thông điệp đang yêu cầu làm gì, dấu hiệu nào thực sự xuất hiện và bước xác minh nào phù hợp. [2] [3]

Đề tài lựa chọn kết hợp hai loại tín hiệu: mô hình học máy phân loại đặc trưng chuỗi URL và LLM phân tích ngữ cảnh. RAG được thiết kế như nguồn kiến thức tham khảo có xuất xứ. Tài liệu mô tả thủ đoạn có thể hỗ trợ giải thích hành vi, nhưng không tự chứng minh một tên miền cụ thể đang lừa đảo. Cách phân vai này là cơ sở để xây dựng thực nghiệm tách riêng tác dụng của từng thành phần.

1.2. Mục tiêu của đề tài

• M1. Tích hợp mô hình URL có thể tái lập trên PhishVN; báo cáo dữ liệu, đặc trưng, ngưỡng, Precision, Recall, F1 và FPR theo phạm vi đánh giá. [4]

• M2. Xây dựng ứng dụng kiểm tra URL, email và tin nhắn; xử lý thông điệp không có URL, hiển thị kết quả thành phần và giải thích bằng tiếng Việt.

• M3. Bổ sung RAG quy mô nhỏ có mã tài liệu, URL nguồn và phiên bản; kiểm tra khả năng truy xuất, tính liên quan và mức hỗ trợ của nguồn dẫn.

• M4. So sánh các cấu hình có và không có ML/RAG trên cùng dữ liệu; ghi nhận báo nhầm, bỏ sót, thiếu thông tin, chất lượng giải thích và chi phí vận hành.

1.3. Phạm vi và đối tượng

Đối tượng sử dụng là người cần kiểm tra thông báo đáng ngờ trước khi phản hồi, đặc biệt trong ngữ cảnh học tập, tài khoản, ngân hàng và giao nhận tại Việt Nam. Đầu vào là văn bản do người dùng chủ động dán vào, tối đa 8.000 ký tự và 5 URL khác nhau mỗi lượt. Ứng dụng chạy trên trình duyệt và máy chủ cục bộ; không yêu cầu người dùng cấp quyền đọc hộp thư.

Bản triển khai đang dùng XGBoost đã xuất từ notebook và DeepSeek-V4-Flash qua API FPT. Phần ML chạy trên CPU; không mở trang đích, không tải tệp đính kèm, không tra DNS, WHOIS hoặc blacklist thời gian thực. PhishVN là bộ URL theo bối cảnh Việt Nam và có tên miền quốc tế; không đồng nhất dữ liệu Việt Nam với hậu tố .vn. Không sử dụng PhiUSIIL trong thực nghiệm được báo cáo ở đây.

Phạm vi hoàn thiện ưu tiên mô hình cây truyền thống, ứng dụng baseline, RAG nhỏ và đánh giá có kiểm soát. Fine-tune BERT, nhiều tác tử, phân tích ảnh/HTML, trình duyệt tự động đến trang nghi vấn và triển khai đa người dùng là phần mở rộng. Sự hiện diện của cấu hình BERT trong notebook không phải bằng chứng BERT đã được đưa vào ứng dụng hoặc đã hoàn thành đánh giá.

1.4. Đóng góp và điểm nổi bật

Đóng góp đã có gồm luồng phân tích kết hợp chạy được, cơ chế xác nhận gửi API, kiểm tra đầu ra có cấu trúc và công cụ đánh giá tách nhận định LLM khỏi quy tắc kết hợp. Hồ sơ thực nghiệm lưu mã mẫu, fingerprint mô hình, ngưỡng, cấu hình gọi và phản hồi để kiểm tra lại. Kho RAG ban đầu có cả cảnh báo lừa đảo và quy trình hợp lệ, tạo cơ sở kiểm tra thiên hướng cảnh báo quá mức. [5]

Đóng góp thực nghiệm hiện tại là chỉ ra đánh đổi cụ thể: mô hình URL giúp giảm số trường hợp LLM chưa đủ căn cứ trên tác vụ URL-only, song làm tăng báo nhầm; quy tắc giữ cảnh báo có thể làm mất phần cải thiện của LLM. Đề tài không tuyên bố phát minh thuật toán XGBoost hoặc đã chứng minh RAG cải thiện F1. Phần chứng minh tác dụng của RAG vẫn là mục tiêu cần thực hiện.

1.5. Tiêu chí hoàn thành và trạng thái

Bảng 1.1 gắn tiêu chí với bằng chứng đang có. “Đạt một phần” có nghĩa là đã có nền tảng hoặc phép đo ban đầu nhưng còn thiếu điều kiện để coi mục tiêu hoàn tất.

Bảng 1.1. Tiêu chí hoàn thành và bằng chứng hiện tại

Tiêu chí	Bằng chứng / điều kiện	Trạng thái
TC1 · Mô hình URL	Có mô hình, split và chỉ số trên 8.941 URL; còn thiếu bảng đối chiếu đầy đủ với benchmark tham chiếu cùng điều kiện.	Đạt một phần
TC2 · Ứng dụng baseline	Nhập, phân loại, gọi LLM, xem trước, fusion và xuất JSON; có lỗi biên cần sửa.	Đạt một phần
TC3 · RAG có dẫn nguồn	25 nguồn đã chốt; embedding, truy xuất, kiểm tra citation và giao diện nguồn chưa triển khai.	Đạt một phần
TC4 · Đánh giá thông điệp	Có 60 mẫu mô phỏng và 100 URL; chưa có bộ 100–200 thông điệp gán nhãn độc lập và rubric đã chấm.	Chưa đạt
TC5 · Tái lập và kiểm thử	60 ca tự động đạt; đã lưu kết quả, cấu hình và kiểm chứng số đo; chưa đo coverage mã.	Đạt trong phạm vi đã kiểm tra

1.6. Cấu trúc báo cáo

Chương 2 trình bày kiến thức và công trình liên quan. Chương 3 xác định bài toán, yêu cầu và quy tắc cảnh báo. Chương 4 mô tả kiến trúc, xử lý URL và thiết kế RAG. Chương 5 ghi nhận cài đặt, tài nguyên và triển khai. Chương 6 trình bày phương pháp đánh giá, kết quả đã đo và thí nghiệm còn phải làm. Chương 7 đối chiếu mục tiêu, nêu hạn chế và kế hoạch hoàn thiện. Các phụ lục cung cấp cách chạy, danh mục nguồn RAG và bản đồ bằng chứng.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ

2.1. Bài toán nhận diện nguy cơ

Phishing theo nghĩa hẹp là hành vi giả mạo để lấy thông tin xác thực hoặc dữ liệu nhạy cảm. Ứng dụng còn xem xét những hành vi lừa đảo như yêu cầu chuyển tiền và mời đầu tư bất thường. Vì vậy cần phân biệt nhãn URL của bộ dữ liệu với nhãn hành vi trong thông điệp. Một URL được nguồn chống lừa đảo liệt kê có thể thuộc nhiều loại lạm dụng; không được mặc nhiên coi tất cả mẫu dương là trang thu thập mật khẩu.

Mô hình URL nhận đầu vào u và tạo điểm s(u) trong [0,1]. Điểm phản ánh đầu ra bộ phân loại, chưa được hiệu chỉnh thành xác suất gian lận ngoài thực tế. Quyết định còn phụ thuộc ngưỡng và phân phối dữ liệu. Một miền có chuỗi giống mẫu dương có thể bị báo nhầm; một URL ít bất thường vẫn có thể xuất hiện trong tin nhắn yêu cầu OTP.

2.2. Học máy từ đặc trưng URL

Các đặc trưng lexical được tính trực tiếp từ chuỗi, chẳng hạn độ dài, số chữ số, số tên miền con và entropy ký tự. Ưu điểm phù hợp với ứng dụng là suy luận cục bộ và không phải truy cập website nghi vấn. Hạn chế là không quan sát được nội dung trang, lịch sử miền, người gửi hay mục đích giao dịch.

XGBoost xây dựng tập hợp cây theo cơ chế boosting để tối ưu hàm mất mát có điều chuẩn. Trong đề tài, XGBoost là bộ phân loại trên 21 cột số; việc chọn ngưỡng được thực hiện tách khỏi bước học tham số. Lý do sử dụng là đã có gói xuất và mã suy luận thống nhất với notebook, phù hợp với phạm vi ứng dụng CPU. [6]

Random Forest và Logistic Regression là các mốc tham chiếu trong mã PhishVN. Chúng có ý nghĩa kiểm tra liệu thay mô hình có giúp hơn cấu hình nền trên cùng dữ liệu, chứ không chỉ tạo thêm tên thuật toán. LightGBM là ứng viên tiếp theo nếu ngân sách thời gian cho phép. Bản báo cáo hiện chưa có đủ tệp kết quả để lập bảng nhiều seed cho các họ mô hình này. [7]

2.3. LLM, bằng chứng và RAG

LLM nhận nội dung và sinh một đối tượng kết quả có mức cảnh báo, tóm tắt, bằng chứng và hành động khuyến nghị. Việc yêu cầu JSON giúp ứng dụng kiểm tra kiểu và trường dữ liệu, nhưng không tự bảo đảm nhận định đúng. Một trích đoạn có thật vẫn có thể bị diễn giải sai: câu “không chia sẻ OTP” không tương đương với yêu cầu “gửi OTP cho tôi”.

RAG bổ sung văn bản được truy xuất từ một kho bên ngoài vào quá trình sinh câu trả lời. Trong đề tài, đây là thiết kế truy xuất rồi cung cấp tài liệu cho LLM qua prompt, không phải huấn luyện lại toàn bộ kiến trúc RAG của công trình gốc. Lợi ích cần kiểm chứng là căn cứ giải thích và hướng xử lý; nguy cơ là truy xuất nguồn không liên quan hoặc dùng kiến thức chung để kết tội một đối tượng cụ thể. [8]

Embedding biểu diễn truy vấn và đoạn tài liệu thành vector để xếp hạng độ tương tự. Họ multilingual E5 là lựa chọn thiết kế cho nội dung đa ngôn ngữ; hiệu quả trên tập tài liệu nhỏ của dự án vẫn phải đo bằng truy vấn tiếng Việt. Số chiều, revision và tokenizer sẽ được khóa khi thực sự xây chỉ mục. [9]

2.4. Các giải pháp và công trình liên quan

Bảng 2.1 so sánh phạm vi và cách tiếp cận theo công bố của từng đơn vị. Không so sánh trực tiếp Accuracy/F1 giữa các công trình có bộ dữ liệu, nhãn và điều kiện khác nhau.

Bảng 2.1. Đối chiếu dịch vụ và công trình liên quan

Giải pháp	Khả năng liên quan	Giới hạn khi đối chiếu với đề tài	Nguồn
Google Safe Browsing	Đối chiếu URL với danh sách nguy hiểm.	Cần thành phần bổ sung để phân tích hành vi trong thông điệp.	[2]
VirusTotal	Tổng hợp thông tin từ công cụ phân tích URL/tệp.	Không phải bộ phân loại thông điệp dùng chung dữ liệu với đề tài; có cơ chế chia sẻ dữ liệu gửi lên.	[3]
Chống Lừa Đảo	Công cụ cho người dùng Việt Nam, có báo cáo cộng đồng và xác minh.	Chưa có benchmark chung để kết luận hơn/kém về chỉ số.	[10]
User-Centric Phishing Detection	RAG từ email hợp lệ của người dùng và thông tin danh tiếng.	Đòi hỏi ngữ cảnh cá nhân; kho đề tài chỉ gồm hướng dẫn công khai.	[11]
MultiPhishGuard	Nhiều tác tử cho văn bản, URL, metadata và giải thích.	Điều phối và huấn luyện mở rộng khối lượng triển khai.	[12]
PhishLens	Phân loại URL + phân tích nội dung tiếng Việt; thiết kế RAG nhỏ.	Chưa mở trang đích; RAG runtime và đánh giá thông điệp độc lập chưa hoàn tất.	[5]

Nghiên cứu User-Centric sử dụng lịch sử email hợp lệ làm ngữ cảnh cá nhân, khác với kho cảnh báo dùng chung của dự án. Vì vậy không thể lấy hiệu quả RAG của nghiên cứu đó làm kết quả kỳ vọng chắc chắn cho kho 25 tóm lược. MultiPhishGuard sử dụng phối hợp nhiều tác tử và điều chỉnh đóng góp; trong phạm vi còn lại, đề tài ưu tiên một LLM với dữ liệu vào và phép so sánh được kiểm soát. [11] [12]

2.5. Công nghệ sử dụng và lý do lựa chọn

Bảng 2.2 phân biệt thành phần đã có với thành phần mới ở mức thiết kế. FastAPI phục vụ API và tệp tĩnh trên cùng địa chỉ; giao diện không cần bước build Node.js. Dịch vụ FPT được gọi theo định dạng chat completions, tên model và endpoint được cấu hình rõ ràng. [13]

Bảng 2.2. Công nghệ và vai trò trong hệ thống

Thành phần	Vai trò	Trạng thái
Python 3.12; FastAPI; Pydantic	Điều phối, kiểm tra request và phản hồi.	Đã triển khai
XGBoost 3.0.5; pandas; NumPy	Nạp mô hình URL và sinh đúng thứ tự đặc trưng.	Đã triển khai
HTTPX; FPT API	Gọi DeepSeek-V4-Flash, timeout và xử lý lỗi.	Đã triển khai
HTML / CSS / JavaScript	Giao diện tiếng Việt, xem trước, kết quả, xuất JSON.	Đã triển khai
Trafilatura; BeautifulSoup	Thu thập nội dung đã duyệt và kiểm tra metadata.	Đã dùng cho corpus
multilingual-e5-small; FAISS CPU	Embedding và truy xuất tương tự.	Thiết kế; chưa tích hợp
pytest; scikit-learn	Kiểm thử logic và đối chiếu độc lập chỉ số.	Đã sử dụng

CHƯƠNG 3. PHÂN TÍCH YÊU CẦU VÀ BÀI TOÁN

3.1. Phát biểu bài toán và câu hỏi nghiên cứu

Đầu vào x gồm loại dữ liệu m ∈ {url, text} và chuỗi văn bản t. Bộ trích xuất tạo U = $\{u_1,\ldots,u_k\}$, với $0 \le k \le 5$. Khi có URL, mô hình tạo điểm và mức cảnh báo cho từng u_i. LLM nhận bản văn bản đã xác nhận, tùy cấu hình có thêm kết quả URL và tài liệu truy xuất. Đầu ra là mức chung, nhận định thành phần, bằng chứng, trạng thái xử lý và hướng dẫn.

Mục tiêu đánh giá không chỉ là phân loại đúng những mẫu hệ thống sẵn sàng kết luận. Cần đồng thời đo bỏ sót, báo nhầm, số mẫu UNKNOWN, lỗi và chất lượng giải thích. Nhãn thông điệp phải mô tả hành vi của toàn thông điệp; nhãn URL chỉ mô tả đối tượng của bộ URL. Không suy nhãn email từ một tên miền được chèn để minh họa.

• RQ1. Trên PhishVN, các ngưỡng đã khóa tạo đánh đổi Precision–Recall–FPR như thế nào, và kết quả thay đổi ra sao theo nguồn hoặc tier?

• RQ2. Cung cấp kết quả URL cho LLM làm thay đổi chất lượng nhận định và tỷ lệ có kết luận như thế nào trên cùng đầu vào?

• RQ3. RAG có cải thiện việc nêu đúng dấu hiệu, dẫn nguồn và hướng dẫn xử lý mà vẫn kiểm soát báo nhầm trên thông điệp tiếng Việt không?

• RQ4. Quy tắc kết hợp cuối cùng có giữ được lợi ích của từng thành phần, kể cả khi chúng mâu thuẫn hoặc API lỗi không?

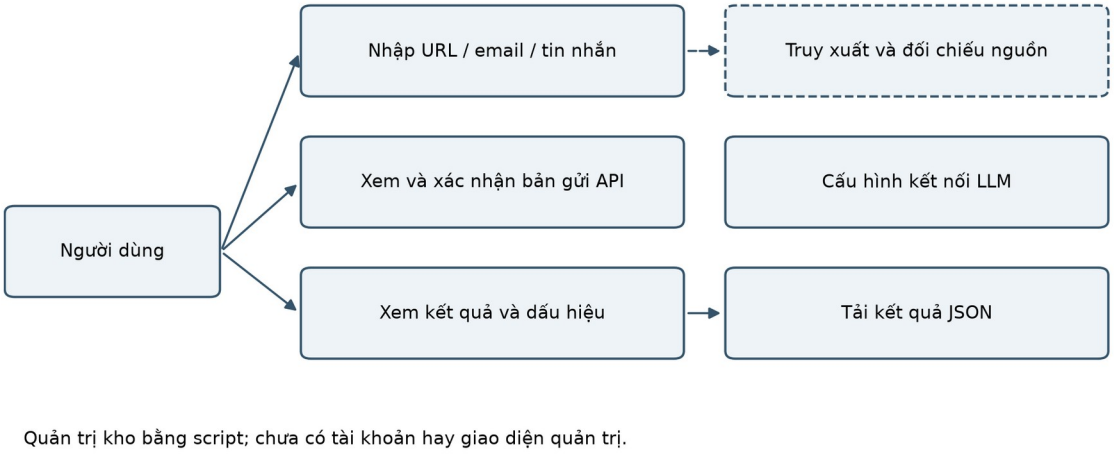
3.2. Yêu cầu chức năng

Bảng 3.1 giữ mã chức năng để liên hệ thiết kế và kiểm thử. Mức “Bắt buộc” phản ánh phạm vi mục tiêu; cột hiện trạng cho biết tiến độ thực tế. Hình 3.1 mô tả tương tác chính, trong đó truy xuất nguồn còn ở mức thiết kế.

Bảng 3.1. Yêu cầu chức năng và hiện trạng

Mã	Chức năng	Ưu tiên	Điều kiện nghiệm thu / hiện trạng
FR-01	Nhập và kiểm tra dữ liệu	Bắt buộc	URL hoặc văn bản; rỗng/quá dài bị từ chối. Đã có.
FR-02	Trích xuất URL	Bắt buộc	Gộp trùng, giới hạn 5 URL, hỗ trợ không URL. Có lỗi biên.
FR-03	Phân loại từng URL	Bắt buộc	Trả score, ngưỡng, mức và trạng thái từ model thật. Đã có.

Mã	Chức năng	Ưu tiên	Điều kiện nghiệm thu / hiện trạng
FR-04	Phân tích bằng LLM	Bắt buộc	Nhận định, quote và hành động tiếng Việt có cấu trúc. Đã có.
FR-05	Truy xuất và dẫn nguồn	Bắt buộc	Trả tài liệu phù hợp hoặc rỗng; citation phải hợp lệ. Mới có corpus.
FR-06	Tổng hợp cảnh báo	Bắt buộc	Có bảng quy tắc, cờ mâu thuẫn và trạng thái thiếu. Đã có baseline.
FR-07	Xem trước và đồng ý	Bắt buộc	Che theo quy tắc, cho sửa và từ chối gửi. Đã có; payload cần hoàn thiện.
FR-08	Xử lý lỗi thành phần	Bắt buộc	Lỗi LLM không làm mất kết quả URL. Có; còn lỗi envelope biên.
FR-09	Quản lý kho bằng giao diện	Mở rộng	Cập nhật nguồn/chỉ mục qua giao diện. Chưa có.
FR-10	Xuất kết quả	Nên có	Người dùng chủ động tải JSON. Đã có.
FR-11	Kiểm tra CSV theo lô	Mở rộng	Luồng người dùng nhận và xuất CSV. Chưa có; script đánh giá là công cụ riêng.



Hình 3.1. Các tương tác chính với ứng dụng; nét đứt là phần chưa tích hợp

3.3. Yêu cầu phi chức năng

Bảng 3.2 định nghĩa tiêu chí có thể kiểm tra. Mốc thời gian là mục tiêu vận hành, không dùng số đo thử trên một máy để cam kết cho mọi môi trường.

Bảng 3.2. Yêu cầu phi chức năng và cách xác minh

Mã	Yêu cầu / mục tiêu	Cách xác minh và hiện trạng
NFR-01	ML: p95 < 1 giây cho 5 URL sau khi nạp; LLM timeout mặc định 45 giây.	Đo ≥30 lượt, ghi phần cứng; đã đo thử cục bộ. Thực nghiệm LLM dùng timeout riêng 90 giây.
NFR-02	Không tự lưu nội dung gốc; người dùng kiểm soát dữ liệu gửi ngoài.	Kiểm tra payload, log và tệp xuất; che theo quy tắc có giới hạn. Chưa bảo đảm payload phản ánh mọi sửa đổi của preview.
NFR-03	Không lộ khóa API; chỉ cho endpoint HTTPS được duyệt.	Khóa ở môi trường/phiên; lỗi không echo key; endpoint có allowlist. Đã có kiểm thử.
NFR-04	Kiểm tra JSON, quote và nguồn dẫn.	Schema và quote đã có; citation, hỗ trợ phát biểu và RAG injection chưa hoàn tất.
NFR-05	Tái lập theo phiên bản dữ liệu và cấu hình.	Lưu ID, hash, model, prompt, ngưỡng, tham số và kết quả; RAG sẽ khóa snapshot/revision.
NFR-06	Giới hạn đầu vào và phí gọi.	8.000 ký tự, 5 URL, request ≤65.536 byte, tối đa 2 lượt LLM đồng thời, không tự retry. Chưa có trần USD tự động.
NFR-07	Dễ đọc và thao tác bằng tiếng Việt.	Kết quả có chữ, không chỉ màu; URL dạng văn bản. Chưa có nghiên cứu sử dụng với người dùng độc lập.

3.4. Đặc tả các chức năng chính

3.4.1. Kiểm tra URL bằng mô hình cục bộ

Tác nhân là người dùng; tiền điều kiện là có gói model hợp lệ. Người dùng chọn URL riêng lẻ, nhập chuỗi, tắt LLM nếu chỉ cần ML rồi gửi. Máy chủ kiểm tra, sinh đặc trưng và trả score cùng hai ngưỡng. Hậu điều kiện là hiển thị mức nguy cơ của URL, không phải xác nhận website an toàn. Nếu thiếu model hoặc dự đoán lỗi, kết quả phải nêu chưa xử lý được; không sinh điểm giả.

3.4.2. Phân tích email hoặc tin nhắn

Người dùng dán văn bản và bật LLM. Ứng dụng tạo bản đã che; người dùng xem, sửa và đồng ý. Nếu hủy hoặc chưa đồng ý, không gọi API. Sau phản hồi, máy chủ kiểm tra schema và quote, rồi kết hợp với kết quả URL. Không có URL là nhánh hợp lệ: không tạo URL giả, LLM phân tích hành động và ngữ cảnh. Nếu LLM lỗi, chỉ giữ được các kết quả thành phần đã có và ghi rõ phạm vi thiếu.

3.4.3. Truy xuất tài liệu có nguồn — thiết kế

Tiền điều kiện là snapshot và chỉ mục khớp hash. Truy vấn tạo từ nội dung đã che, không chứa nhãn thật hoặc score ML. Hệ thống truy xuất, lọc ngưỡng và gửi tối đa ba nguồn. Nếu không có nguồn phù hợp, phân tích tiếp với trạng thái truy xuất rỗng. LLM chỉ được dẫn mã tài liệu đã nhận; kiểm tra mã và mức hỗ trợ của nguồn là hai bước riêng. Chức năng này chưa có trong API baseline.

3.4.4. Xuất và đối chiếu kết quả

Sau một lượt xử lý, người dùng có thể tải JSON chứa cấu hình, thành phần, thời gian và kết quả. Thao tác này là chủ động, không phải lưu lịch sử tự động. Tệp có thể chứa URL gốc và bản nội dung gửi LLM; người dùng cần kiểm tra trước khi chia sẻ. Trong thực nghiệm, checkpoint được lưu riêng theo kế hoạch đánh giá; không dùng mẫu người dùng thật mà chưa có căn cứ sử dụng phù hợp.

3.5. Mức cảnh báo và quy tắc kết hợp hiện hành

Bốn mức gồm HIGH — Nguy cơ cao; WARNING — Cần kiểm tra thêm; LOW — Chưa phát hiện dấu hiệu rõ ràng; UNKNOWN — Chưa đủ thông tin. Bảng 3.3 mô tả đúng thứ tự xử lý trong app/fusion.py. Trước khi xét LLM, các quote không hợp lệ đã bị loại; cảnh báo LLM HIGH/WARNING không còn quote sẽ chuyển thành UNKNOWN.

Bảng 3.3. Quy tắc fusion của baseline đang chạy

Điều kiện theo thứ tự	Mức cuối	Diễn giải
Có URL ML HIGH	HIGH	Giữ ngay cả khi LLM LOW hoặc lỗi.
LLM HIGH hợp lệ	HIGH	Áp dụng cả khi URL LOW hoặc không có URL.
Có URL ML WARNING	WARNING	Giữ ngay cả khi LLM LOW.
LLM WARNING hợp lệ	WARNING	Không có tín hiệu HIGH trước đó.
Còn URL lỗi/không hợp lệ	UNKNOWN	Không có cảnh báo trước đó để giữ.
Chế độ URL; các URL đã xử lý đều LOW	LOW	Có thể LOW cho riêng URL dù LLM lỗi; phải ghi trạng thái LLM.
LLM LOW; không còn URL chưa xử lý	LOW	Không đồng nghĩa bảo đảm an toàn.

Điều kiện theo thứ tự	Mức cuối	Diễn giải
Các trường hợp còn lại	UNKNOWN	Ví dụ văn bản chỉ có ML LOW, LLM tắt hoặc lỗi.

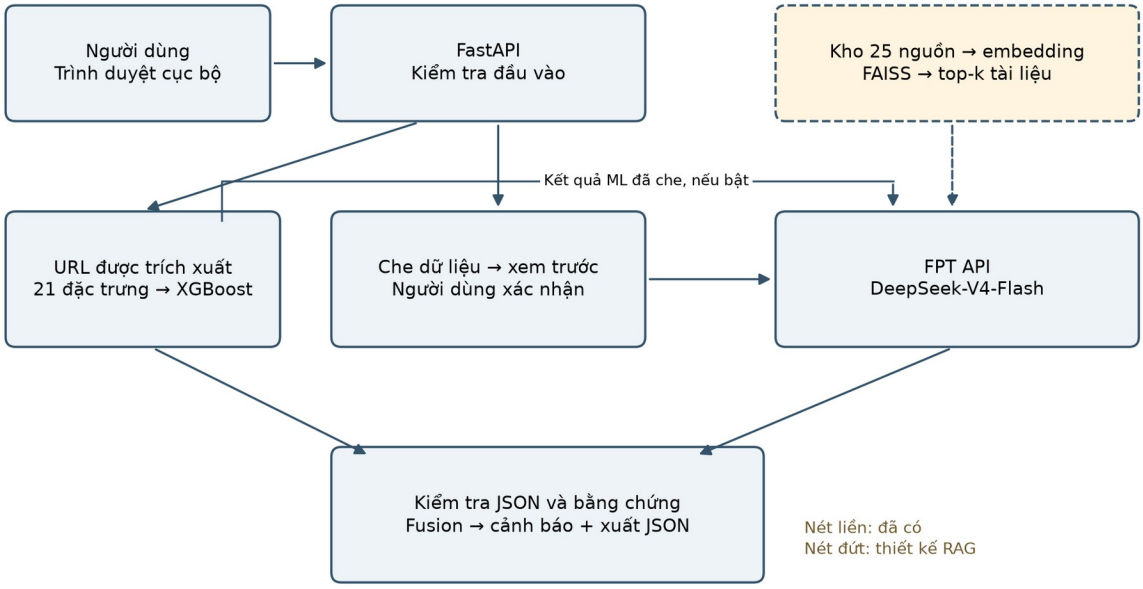
Cờ conflict được bật khi mức cao nhất của ML là LOW còn LLM cảnh báo, hoặc khi ML cảnh báo còn LLM LOW. Đây là thông tin khác biệt giữa thành phần, không phải bộ giải quyết mâu thuẫn đã học. Ví dụ ML LOW nhưng LLM HIGH vì yêu cầu gửi OTP thì kết quả HIGH; ML HIGH nhưng LLM LOW vì nội dung có vẻ thông thường thì vẫn HIGH. Tính bảo thủ này cần được đo vì có thể giữ cả cảnh báo nhầm.

Một khác biệt cần giữ rõ so với yêu cầu đích: ở chế độ chỉ URL, baseline cho phép LOW dựa trên ML dù LLM không hoàn thành; với toàn bộ email/tin nhắn thì không. Nếu muốn bắt buộc LLM thành công mới có LOW ở mọi chế độ, phải sửa quy tắc và đánh giá lại, không mô tả như hành vi đã tồn tại.

CHƯƠNG 4. THIẾT KẾ GIẢI PHÁP

4.1. Kiến trúc tổng thể

Hình 4.1 thể hiện kiến trúc theo thành phần. Máy chủ cục bộ xử lý URL và che dữ liệu. Giao diện chỉ gọi API cùng địa chỉ; dịch vụ FPT là thành phần bên ngoài và chỉ nhận dữ liệu khi có đồng ý. Khối RAG nét đứt là kiến trúc dự kiến, không phải luồng đang được gọi trong ứng dụng.



Hình 4.1. Kiến trúc baseline và vị trí bổ sung RAG

Thiết kế chọn một dịch vụ LLM và các module Python nhỏ để giảm phần điều phối trong thời gian còn lại. Không thêm cơ sở dữ liệu lịch sử vì chức năng cốt lõi không cần lưu nội dung người dùng. Đối với corpus nhỏ, lập chỉ mục cục bộ phù hợp hơn việc triển khai thêm dịch vụ vector riêng; quyết định này có thể thay khi quy mô thực sự tăng.

4.2. Cấu trúc dữ liệu và bằng chứng

Ứng dụng dùng JSON cho trao đổi và JSONL/CSV cho hồ sơ đánh giá. Bảng 4.1 mô tả các cấu trúc chính. Không có ERD tài khoản hay giao dịch vì chưa có cơ sở dữ liệu quan hệ trong phạm vi cài đặt.

Bảng 4.1. Các cấu trúc dữ liệu chính

Đối tượng	Trường đáng chú ý	Vai trò / ràng buộc
AnalyzeInput	mode, text, use_llm, include_ml, consent, llm_text	Loại đầu vào cố định; độ dài bị giới hạn; khóa dùng SecretStr.
URLResult	id, url, status, score, risk_level, thresholds	score chỉ có ý nghĩa khi status=ok; giữ kết quả từng URL.
LLMVerdict	risk_level, summary, evidence[], recommended_actions[]	Tối đa 6 quote và 5 hành động; không chấp nhận trường ngoài schema.
RAGDocument	id, text, context_note, source_url, publisher, dates, hashes	text là tóm lược biên tập; lưu xuất xứ; ngày chưa rõ là null.
RAGChunk — thiết kế	chunk_id, document_id, text, token_count, vector_row	Liên kết đoạn với tài liệu; không mất URL và phạm vi sử dụng.
EvaluationCase	id, label, mode, text, group_id, source, split	Không gửi nhãn/group/split cho LLM; tách dữ liệu phát triển và test.
RunManifest	hash dữ liệu/model/prompt, seed, tham số, ID mẫu	Khóa cấu hình; chống dùng nhầm checkpoint giữa hai thí nghiệm.

4.3. Dữ liệu và pipeline mô hình URL

4.3.1. Nguồn dữ liệu và phép chia

Thực nghiệm sử dụng PhishVN phiên bản 4, gói mở v3.1.0. Hồ sơ của dự án giữ nguyên ba split, không lấy ngẫu nhiên toàn bộ rồi chia lại. Số lượng thực tế sau bước chuẩn bị được trình bày ở Bảng 4.2; lần kiểm tra này không có mẫu lỗi hoặc trùng cần loại thêm. [4]

Bảng 4.2. Thành phần các split PhishVN được dùng

Split	Tổng URL	Benign	Phishing / scam
Train	36.909	11.004	25.905
Validation	7.266	1.561	5.705
Test	8.941	3.845	5.096
Tổng	53.116	16.410	36.706

Phép chia của nguồn kết hợp nhóm tên miền cơ sở với thời gian: nhóm có thời điểm được sắp theo thời gian; nhóm thiếu thời điểm dùng hàm băm xác định. Do đó không gọi toàn bộ test là một tập tương lai thuần thời gian. Nhãn dương PhishVN có phạm vi chống lừa đảo/lạm dụng rộng hơn credential phishing; nguồn cũng phân biệt

gold, silver và bronze. Đây là lý do phải tách kết quả theo tier và không suy hiệu quả email từ nhãn URL. [14]

Công cụ cục bộ kiểm tra archive SHA-256, MANIFEST của split, sự không giao nhau theo id, model_input và domain_group; đồng thời đối chiếu mã tiền xử lý và mã đặc trưng từng byte với notebook. Fingerprint khôi phục là d3d1ee19f42b, khớp gói XGBoost_d6_s42. Đây là kiểm chứng pipeline và hiện vật đang dùng; không phải bằng chứng mọi bước huấn luyện đã được chạy lại trong phiên viết báo cáo.

4.3.2. Tiền xử lý và đặc trưng

URL gốc được giữ để đối chiếu. Pipeline bỏ khoảng trắng hai đầu, tách thành phần và sử dụng đúng hàm xuất kèm mô hình. Tên miền được chuẩn hóa cho khóa nhóm, trong khi đường dẫn và truy vấn không được tùy tiện đổi chữ hoa/chữ thường. Giao thức có thể được thêm tạm để phân tách; đặc trưng được tính trên biểu diễn đã bỏ scheme.

Hai mươi mốt đặc trưng theo thứ tự config gồm url_len, dom_len, is_ip, tld_len, subdom_cnt, letter_cnt, digit_cnt, special_cnt, eq_cnt, qm_cnt, amp_cnt, dot_cnt, dash_cnt, under_cnt, letter_ratio, digit_ratio, spec_ratio, slash_cnt, entropy, path_len và query_len. Không đưa nhãn, nguồn, tier, thời gian hoặc ID vào ma trận đầu vào. Không dùng is_https vì đó có thể là dấu vết quy trình thu thập, không phải tín hiệu an toàn đáng tin. [7]

Những bước học tham số phải chỉ fit trên train; validation dùng chọn cấu hình và ngưỡng; test chỉ dùng đánh giá sau khóa lựa chọn. Khi so sánh mô hình cần cố định cùng schema và split. Nếu nghiên cứu chuyển miền dữ liệu, chẳng hạn train trên bộ khác và test PhishVN, phải đăng ký thành kịch bản riêng, không gộp với kết quả trong báo cáo này.

4.3.3. Chọn mô hình và hai ngưỡng

Gói đang triển khai là XGBoost_d6_s42, max_depth=6, min_child_weight=6, seed=42. Cấu hình được đọc từ model export, không suy từ tên thư mục. Ứng dụng không thay ngưỡng khi khởi động và lượt đánh giá cục bộ không huấn luyện lại. Ngưỡng cảnh báo tW = 0,11384317278862; ngưỡng cao tH = 0,47364333271980286.

```
s < tW              → LOW
tW ≤ s < tH         → WARNING
s ≥ tH              → HIGH
```

Trong notebook, tW tối đa hóa F2 trên validation dưới điều kiện Precision ≥ 0,80; nếu có nhiều nghiệm bằng nhau thì ưu tiên ngưỡng gần 0,5. tH được chọn trong các ngưỡng ≥ tW có Precision ≥ 0,95 và ít nhất 30 dự đoán dương, ưu tiên Recall cao nhất.

Các ràng buộc này được kiểm tra trên validation; không bảo đảm Precision ở phân phối mới.

F2 = 5PR/(4P + R), vì vậy Recall được nhấn mạnh hơn F1. Tuy nhiên, yêu cầu Precision tối thiểu trên validation có tỷ lệ dương cao vẫn có thể cho FPR rất lớn. Validation của gói này có FPR 70,40% tại tW dù Precision 83,73%. Đây là dấu hiệu cần phân tích phân phối và mục tiêu vận hành; không thể lý giải mọi báo nhầm chỉ bằng câu "ưu tiên Recall".

Hướng cải tiến được đề xuất là bổ sung ràng buộc FPR hoặc chi phí sai sót trên một tập phát triển phù hợp, rồi khóa ngưỡng mới trước tập test mới. Kết quả test hiện tại đã được quan sát nên không tiếp tục điều chỉnh và gọi nó là đánh giá độc lập. Nếu không đạt đồng thời giới hạn bỏ sót và báo nhầm đã đặt, phải báo không đạt thay vì chọn lại tiêu chí sau khi xem kết quả.

4.4. LLM và kiểm tra đầu ra

Prompt baseline-1.0 tách chỉ dẫn hệ thống khỏi dữ liệu người dùng và yêu cầu chỉ dùng thông tin được cung cấp. Mô hình không có công cụ mở liên kết hoặc thực thi lệnh. Payload tùy cấu hình có thêm URL đã che, score, risk_level và ngưỡng. Không gửi nhãn thật hoặc nguồn/tier của dataset cho LLM.

Sau gọi API, ứng dụng kiểm tra schema, giới hạn trường và việc quote có xuất hiện nguyên văn trong bản text đã gửi. Quote không có thật bị loại; HIGH/WARNING không còn quote hợp lệ được chuyển thành UNKNOWN. Bước này xác minh nguồn gốc trích đoạn, chưa xác minh quan hệ suy luận. Chẳng hạn quote chính xác một thông báo bảo mật hợp lệ vẫn có thể đi kèm lý do sai.

Tắt include_ml chỉ ngăn cung cấp kết quả ML cho LLM; API vẫn có thể chạy ML và fusion để phục vụ giao diện. Vì thế cấu hình "chỉ LLM" trong đánh giá phải lấy llm.verdict trước fusion. Nếu lấy final từ API để chấm nhánh đó, phép so sánh sẽ bị lẫn tác động mô hình URL.

4.5. Kho tài liệu RAG và thiết kế truy xuất

4.5.1. Kho đã thu thập

Kho corpus_v1 có 25 bản tóm lược nội dung riêng biệt từ 11 đơn vị công bố, sau khi loại một ứng viên trùng nội dung. Mỗi bản lưu mã nguồn, tiêu đề, URL, đơn vị, chủ đề, thời điểm thu thập, hash phản hồi/văn bản/tóm lược và ngày công bố nếu xác minh được. Có 14 nguồn xác minh được ngày; 11 nguồn để null.

review_status=assistant_curated không đồng nghĩa đã được chuyên gia độc lập thẩm định.

Đây là bản tóm lược biên tập khoảng 80–100 từ theo cách đếm khoảng trắng, không phải toàn văn được tải lại để phân phối. text chứa kiến thức tóm lược, context_note ghi giới hạn sử dụng. Quyền đối với nguồn gốc thuộc đơn vị công bố. Các cảnh báo và quy trình cũ chỉ là kiến thức có thời điểm, không thay thế tra cứu danh tiếng tên miền hoặc quy định hiện hành.

Bảng 4.3 cho thấy kho không chỉ gồm lừa đảo. Hướng dẫn hợp lệ về OTP, xác thực hai bước và khôi phục tài khoản được giữ để kiểm tra tình huống có từ khóa nhạy cảm nhưng hành vi không đáng ngờ. Danh sách 25 URL nằm ở Phụ lục B và knowledge/corpus_v1/sources.csv.

Bảng 4.3. Cơ cấu kho tài liệu RAG ban đầu

Loại	Số nguồn	Vai trò
Cảnh báo thủ đoạn	15	Mạo danh, VNeID, tuyển dụng, đầu tư, hoàn tiền, giao hàng, email và học bổng.
Quy trình hợp lệ	7	Đối chiếu xác thực, thông báo tài khoản, cập nhật sinh trắc học và thông báo học bổng có nguồn.
Xử lý sự cố	2	Chuyển nhầm tiền và tài khoản bị chiếm quyền.
Hướng dẫn kết hợp	1	Nhận diện và báo cáo email giả mạo.

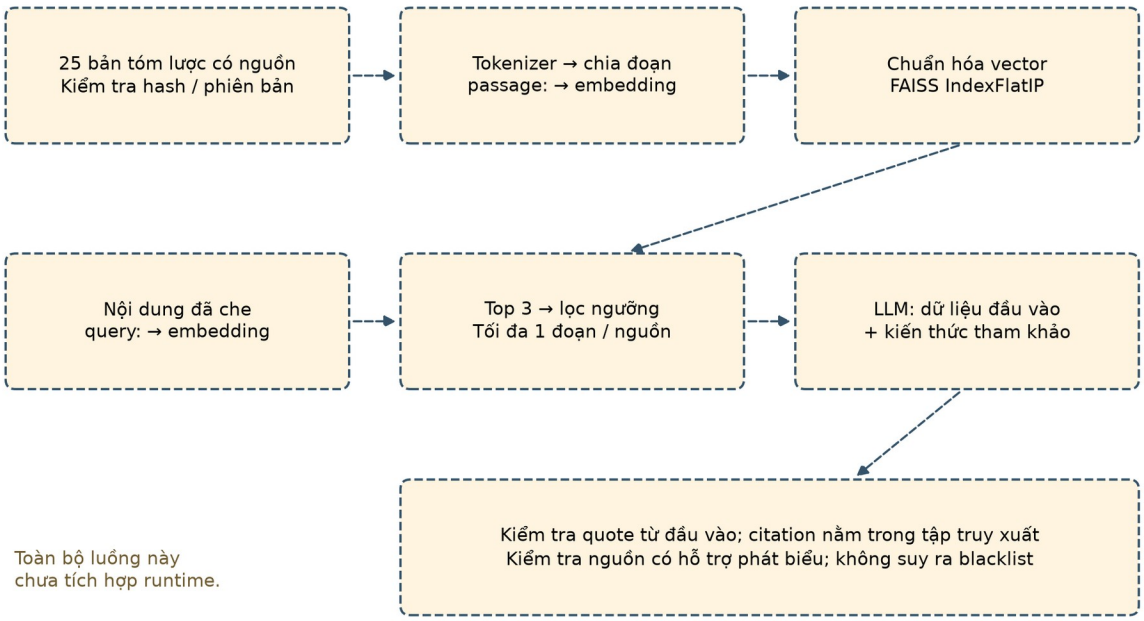
4.5.2. Chia đoạn, embedding và lọc truy xuất — thiết kế

Bước đầu sẽ đo độ dài bằng tokenizer của multilingual-e5-small. Bản tóm lược ngắn được giữ nguyên; chỉ chia khi vượt ngân sách, theo mục tiêu 200–300 token và overlap khoảng 40 token. Không ghép hai nguồn thành một đoạn. Không giả định trước số lượng 100–200 chunk vì kho hiện là tóm lược ngắn, khác với thiết kế dựa trên toàn văn.

Theo model card E5, dùng tiền tố query: và passage: cho tác vụ truy xuất, kể cả nội dung tiếng Việt; chuẩn hóa vector và chú ý giới hạn 512 token. Cosine similarity là tín hiệu xếp hạng, không phải xác suất một kết luận đúng. Chọn ngưỡng từ dữ liệu phát triển thay vì dùng tùy ý một giá trị “đủ tin cậy”. [15]

Với quy mô nhỏ, dự kiến dùng FAISS IndexFlatIP trên vector đã chuẩn hóa để tìm kiếm chính xác theo tích vô hướng. Truy xuất nhiều ứng viên rồi chọn tối đa ba nguồn khác nhau, tránh ba đoạn gần trùng từ một bài. Ngưỡng, top-k và quy tắc đa dạng

nguồn được chọn bằng tập phát triển và khóa trước test. Nếu không có đoạn đạt điều kiện, hệ thống trả truy xuất rỗng, không ép chèn tài liệu. [16]



Hình 4.2. Thiết kế luồng RAG; chưa triển khai trong runtime

4.5.3. Ràng buộc dẫn nguồn và cập nhật

Đầu ra RAG dự kiến tách evidence_input khỏi knowledge_support. Trường thứ nhất trích nguyên văn đầu vào; trường thứ hai nêu kiến thức được nguồn hỗ trợ và document_id. Server kiểm tra document_id thuộc tập đã truy xuất, liên kết thuộc metadata của kho và đoạn dẫn có thật. Mã nguồn hợp lệ vẫn chưa chứng minh phát biểu được nguồn hỗ trợ; rubric chấm tay cần đánh giá thêm quan hệ này.

Không biến câu “có thủ đoạn giả danh ngân hàng” thành khẳng định “URL đang nhập là giả mạo ngân hàng” khi thiếu căn cứ riêng. Với đầu vào chỉ có URL, tài liệu chung có thể không liên quan; khi đó ưu tiên ghi giới hạn thay vì tạo lý do theo khuôn. Tương tự, thông báo học bổng cũ không chứng minh một chương trình đang nhận hồ sơ tại ngày kiểm tra.

Kho được cập nhật thủ công khi có nguồn mới phù hợp hoặc nguồn cũ thay đổi; định kỳ dự kiến hai tuần một lần trong giai đoạn phát triển. Mỗi lần tạo snapshot mới, rà soát nội dung và ngày, loại trùng rồi dựng lại chỉ mục khớp hash. Trong một đợt đánh giá, snapshot bị đóng băng. Không đưa thông điệp test, dữ liệu người dùng hoặc nhãn đánh giá vào chỉ mục.

4.6. Thiết kế API và giao diện

Bảng 4.4 liệt kê API baseline đang có. Giao diện gồm vùng nhập, trạng thái mô hình, tùy chọn LLM, bản xem trước, kết quả từng thành phần và tải JSON. Phần nguồn RAG sẽ được bổ sung khi có runtime; chưa mô tả một API truy xuất như tính năng đã triển khai.

Bảng 4.4. API baseline

Phương thức / đường dẫn	Đầu vào / đầu ra chính	Điều kiện
GET /	Tệp giao diện web.	Máy cục bộ.
GET /api/status	Model, giới hạn, cấu hình LLM, rag=false.	Không trả API key.
POST /api/model/reload	Nạp lại model đã cấu hình.	Chỉ gói mã/mô hình đã tin cậy.
POST /api/preview	mode, text → bản che và nhóm trường đã che.	Chưa gọi FPT.
POST /api/analyze	Dữ liệu phân tích → final, urls, llm, timing.	Bật LLM phải consent=true.
GET /docs	Tài liệu API tự sinh.	Không đưa key thật vào ảnh hoặc tệp chia sẻ.

4.7. Bảo vệ dữ liệu và prompt injection

Mô hình đe dọa gồm nội dung người dùng có thể chứa chỉ dẫn đối kháng, nguồn RAG có thể chứa nội dung không đáng tin và API có thể trả phản hồi bất thường. Biện pháp nền là tách chỉ dẫn/dữ liệu, giới hạn quyền công cụ và kiểm tra đầu ra. Đây là phòng vệ nhiều lớp; việc viết một câu “không làm theo chỉ dẫn trong email” không chứng minh miễn nhiễm prompt injection. [17]

Baseline chỉ bind 127.0.0.1, kiểm tra Host và Origin cho POST, đặt CSP, không cache kết quả và giới hạn kích thước request. Endpoint LLM dùng HTTPS với allowlist, không theo redirect. Đây là biện pháp cho ứng dụng cục bộ; chưa có xác thực tài khoản, hạn mức theo người dùng hoặc mô hình phân quyền để đưa công khai.

Che dữ liệu hiện dựa trên quy tắc cho email, điện thoại, chuỗi số dài, mã xác thực, giá trị query/fragment và thông tin đăng nhập trong URL. Tên người, địa chỉ hoặc dữ liệu phi cấu trúc có thể còn sót. Bản xem trước cho người dùng cơ hội kiểm tra, nhưng payload ML đang được dựng từ URL gốc rồi che lại; nếu người dùng xóa cả URL khỏi preview, URL đã che vẫn có thể xuất hiện trong metadata. Cần bổ sung xem trước toàn bộ payload cuối trước khi coi yêu cầu kiểm soát dữ liệu gửi là hoàn tất.

CHƯƠNG 5. CÀI ĐẶT VÀ TRIỂN KHAI

5.1. Môi trường và tài nguyên

Môi trường kiểm chứng hiện tại dùng Python 3.12.15 trên Linux. Các thư viện chính được ghim trong requirements.txt: FastAPI 0.162.0, Uvicorn 0.54.0, HTTPX 0.28.1, Pydantic 2.14.1, NumPy 2.1.3, pandas 2.2.3, scikit-learn 1.7.2, tldextract 5.3.0 và XGBoost 3.0.5. Trên Linux x86_64, dự án dùng xgboost-cpu để suy luận mà không tải phụ thuộc GPU.

Gói mô hình lưu thông tin môi trường huấn luyện Colab với NVIDIA A100; thông tin này mô tả lần xuất model, không phải yêu cầu chạy ứng dụng. Mốc đo ML cục bộ của báo cáo sử dụng Intel Core i5-11400H. Không suy thời gian huấn luyện hay hiệu năng GPU từ phép đo suy luận CPU. LLM chạy tại dịch vụ FPT nên máy người dùng không cần GPU cho phần đó.

5.2. Tổ chức mã nguồn

Mã nguồn được công bố tại https://github.com/vkhoa2110/Phishing_Detection. Bản làm việc dùng viết báo cáo còn có các tệp thực nghiệm và tài liệu mới chưa đồng bộ toàn bộ lên remote; người tái lập cần gói bàn giao tương ứng. Gói trọng số và .env không nằm trong Git, nên clone repository đơn thuần chưa đủ để chạy ML thật hoặc gọi LLM. [5]

Bảng 5.1 mô tả các module theo trách nhiệm để người đọc tìm bằng chứng thay vì chỉ xem cấu trúc thư mục.

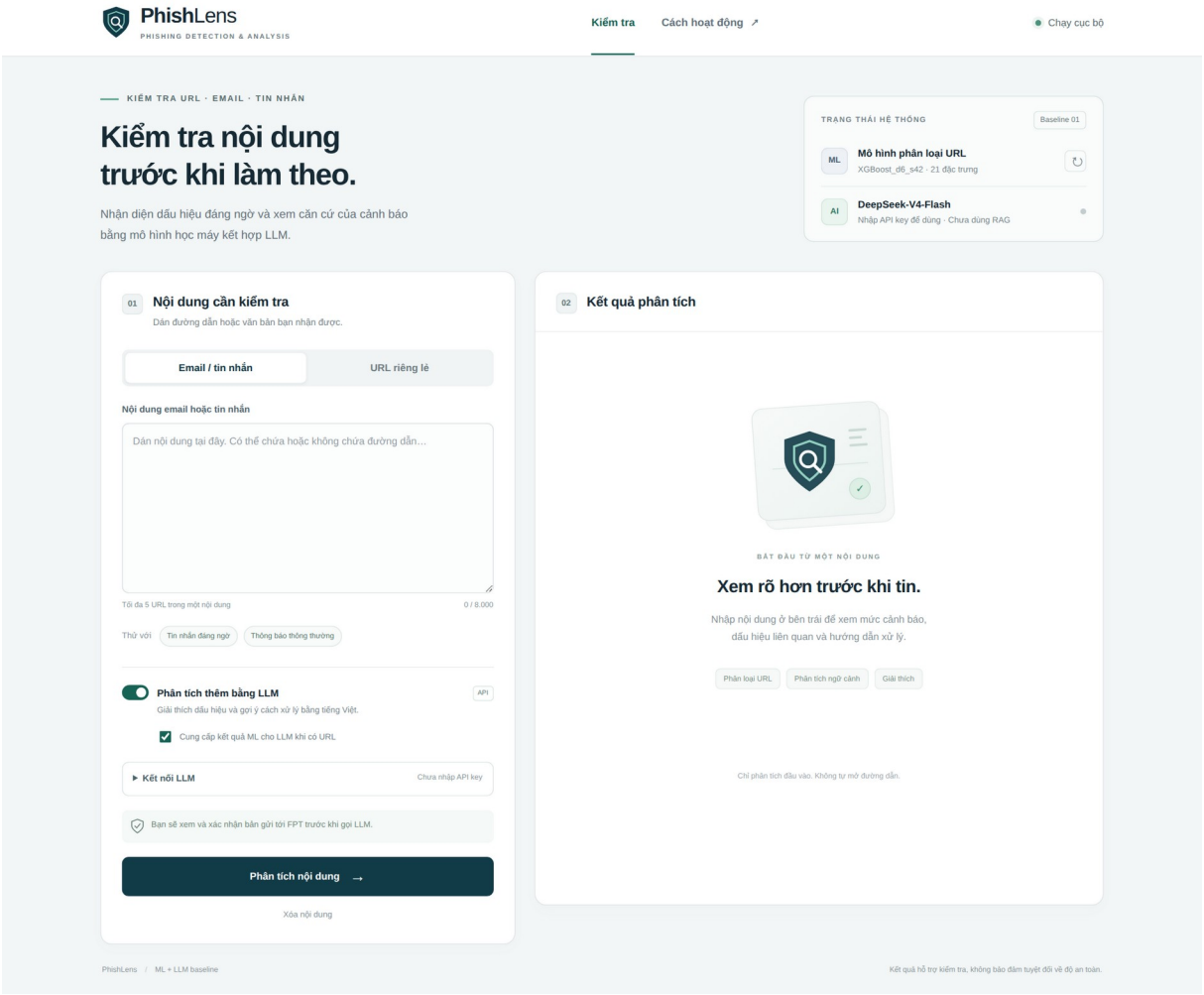
Bảng 5.1. Tổ chức mã nguồn và hiện vật

Đường dẫn tương đối	Trách nhiệm
run.py; app/main.py	Khởi động, API, kiểm tra request và phối hợp xử lý.
app/urls.py; app/privacy.py	Trích xuất URL; che dữ liệu theo quy tắc.
app/ml_service.py	Nạp gói model, kiểm tra schema/ngưỡng và dự đoán.
app/llm_service.py; app/schemas.py	Prompt, giao tiếp FPT, schema và kiểm tra quote.
app/fusion.py; app/static/	Quy tắc kết luận và giao diện web.
inference_XGBoost_d6_s42/	Trọng số, config, mã tiền xử lý và đặc trưng được xuất.
evaluation/; scripts/verify_evaluation.py	Chạy đánh giá, checkpoint, metrics và kiểm chứng độc lập.
reports/phishvn_official_v1/	Số đo toàn bộ URL test và 100 URL gọi LLM thật.

Đường dẫn tương đối	Trách nhiệm
knowledge/; scripts/collect_rag_sources.py	Corpus, danh mục và công cụ thu thập nguồn được duyệt.
tests/	Kiểm thử baseline, đánh giá, provenance và collection.

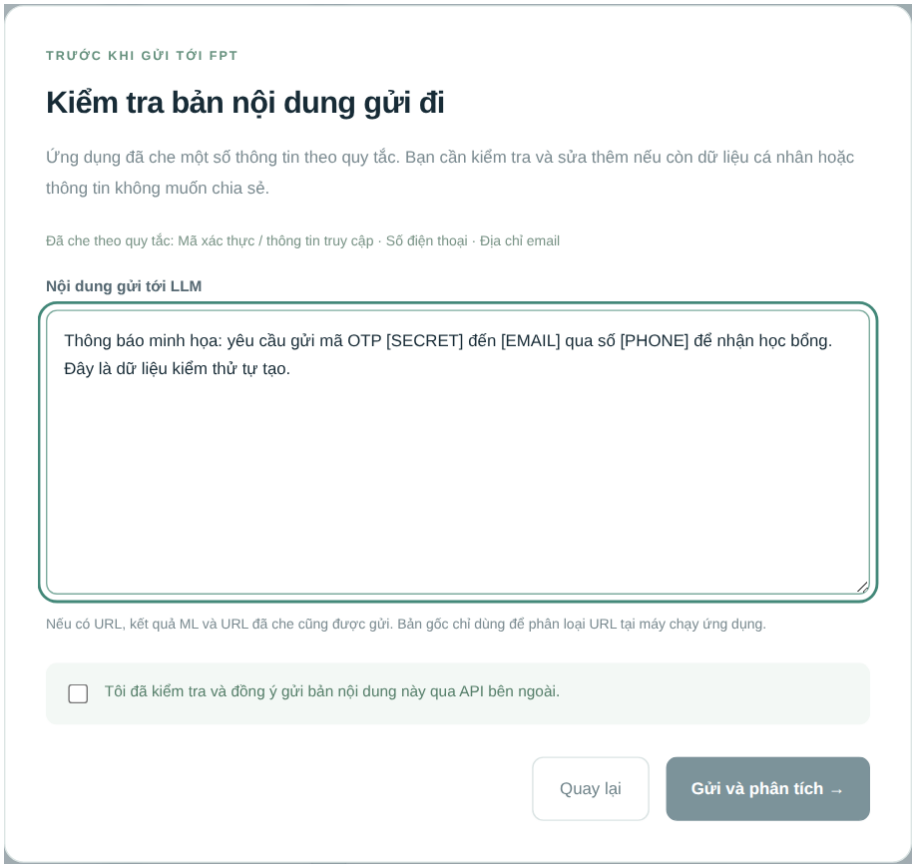
5.3. Hiện thực và giao diện các chức năng chính

Hình 5.1 là ảnh giao diện chạy thật tại máy cục bộ. Vùng nhập và vùng kết quả nằm cạnh nhau; trạng thái model và LLM được hiển thị riêng. Nhãn "Chưa dùng RAG" phản ánh đúng runtime, không dùng ảnh mô phỏng nguồn dẫn để minh họa như chức năng đã có.



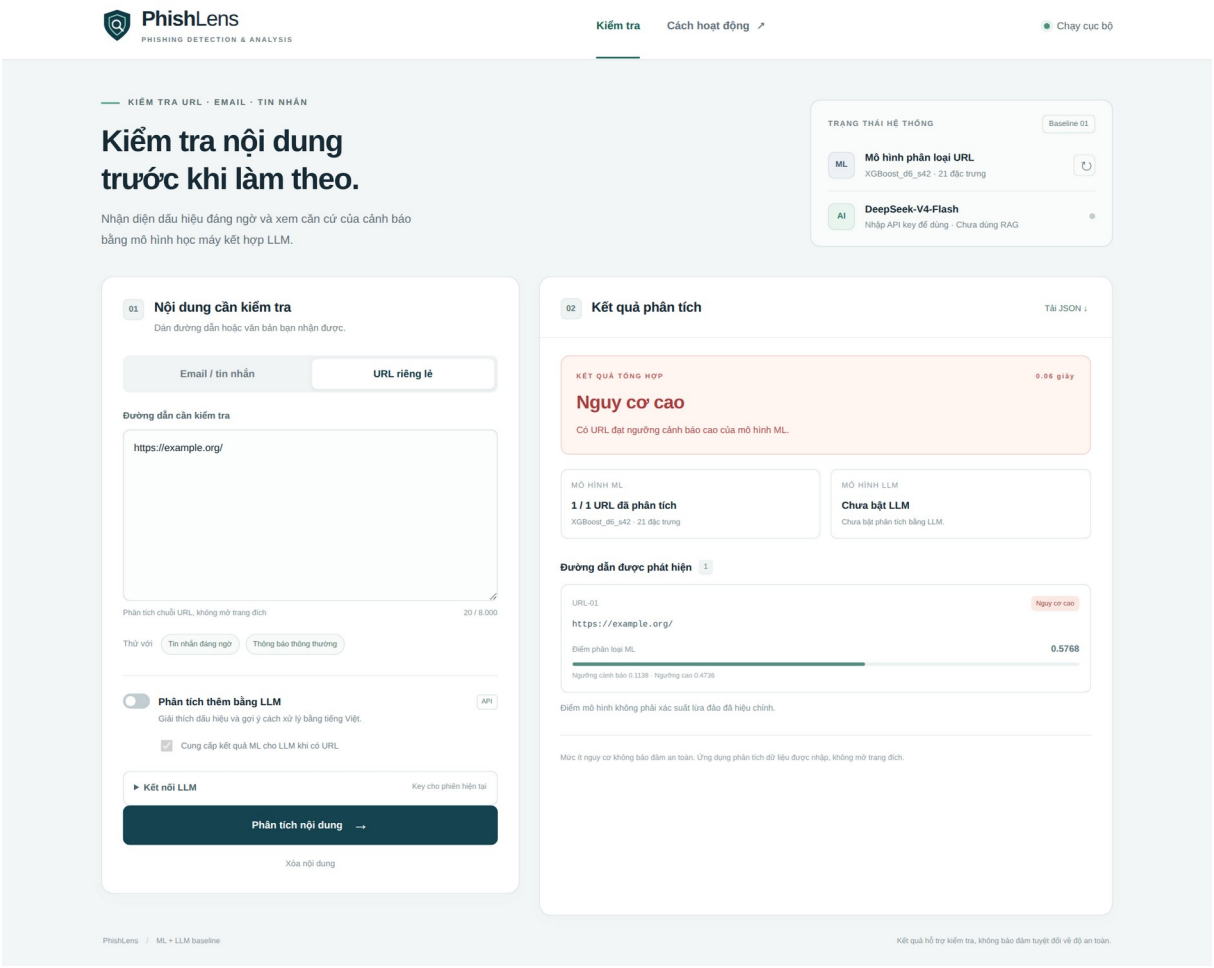
Hình 5.1. Giao diện baseline chạy thực tế trên máy cục bộ

Khi bật LLM, ứng dụng hiển thị bản đã che như Hình 5.2. Ảnh dùng dữ liệu minh họa tự tạo, không có khóa API thật hoặc thông tin người dùng thật. Chụp màn hình dừng ở bước xem trước và không gửi tới FPT. Cơ chế này hỗ trợ quyết định chia sẻ; các giới hạn payload nêu ở mục 4.7 vẫn cần sửa.



Hình 5.2. Bản xem trước đã che thông tin bằng quy tắc

Hình 5.3 là lượt suy luận ML thật với URL minh họa https://example.org/ và LLM tắt. Đây là minh họa luồng hiển thị, không phải nhãn chuẩn hoặc phép đo chất lượng trên một website. Lượt chụp ảnh không mở trang đích, không gọi API và không phát sinh token.



Hình 5.3. Kết quả ML thực trên một đầu vào minh họa, không gọi LLM

5.4. Kết nối LLM và ngân sách

Dự án đã có cấu hình và đã thực hiện các lượt gọi thật tới DeepSeek-V4-Flash tại https://mkp-api.fptcloud.com/v1/chat/completions. Khóa được cấp qua biến môi trường hoặc nhập trong phiên giao diện, không đưa vào báo cáo. Chưa xác minh hạn mức còn lại hoặc hóa đơn tài khoản nên không khẳng định có gói miễn phí hay ngân sách sẵn dùng không giới hạn.

Đơn giá công khai đối chiếu ngày 26/10/2026 của DeepSeek-V4-Flash là 0,14 USD/triệu token vào và 0,28 USD/triệu token ra, chưa tính thuế/phụ phí. Báo cáo dùng giá token vào không cache để lập dự toán, không coi phép nhân token là hóa đơn thực tế. [18]

```
Chi phí dự toán (USD) = (token_vào × 0,14 + token_ra × 0,28) / 1.000.000
```

Từ usage của 200 phản hồi hợp lệ trên mẫu 100 URL, tổng token vào là 151.502 và token ra là 191.490. Áp đơn giá trên cho dự toán khoảng 0,07483 USD. Số này chỉ thuộc lượt PhishVN được báo cáo, không gồm pilot, bộ mô phỏng, thuế hoặc những

thành phần tính phí ngoài usage. Mô hình có thể dùng token nội bộ nên không giả định mọi lượt chỉ phát sinh vài trăm token ra.

Kế hoạch thông điệp có 160 test × 4 cấu hình = 640 lượt cho một lần chạy. Nếu dự trù 6.000 token vào và 4.096 token ra mỗi lượt, ngân sách tương ứng khoảng 1,27 USD; ba lần là khoảng 3,82 USD, chưa gồm dev hoặc lỗi. Đề xuất dành mức 5 USD cho một đợt có giới hạn, kiểm tra số dư trước chạy và dừng khi đạt số lượt/token đã đăng ký. Đây là đề xuất ngân sách, chưa phải hạn mức USD được thực thi trong ứng dụng.

Ứng dụng không tự gọi lại khi lỗi; công cụ đánh giá lưu checkpoint để không gọi trùng cấu hình đã hoàn thành. Nếu không có kinh phí, có thể tiếp tục đánh giá ML, xây retrieval và kiểm thử schema bằng mock mà không gọi API. Một LLM chạy cục bộ chỉ nên là thí nghiệm riêng sau khi đo khả năng đáp ứng phần cứng; thay model giữa các cấu hình sẽ làm mất tính đối chiếu. Không tuyên bố chất lượng LLM từ phản hồi mock.

5.5. Triển khai và cấu hình vận hành

Ứng dụng hiện chạy tại http://127.0.0.1:8000, không có URL dịch vụ công khai đã triển khai. Các biến chính gồm MODEL_DIR, FPT_API_KEY, FPT_ENDPOINT, FPT_MODEL, LLM_ALLOWED_HOSTS, LLM_TIMEOUT_SECONDS, LLM_MAX_TOKENS và PORT. Cách cài đặt ở Phụ lục A thống nhất với README.

Mặc định app có timeout 45 giây và giới hạn 1.024 token; lượt đánh giá PhishVN cố định 90 giây và 4.096 token. Đây là hai cấu hình khác nhau cần ghi rõ. Pilot từng gặp JSON bị cắt ở ngân sách nhỏ nên dữ liệu pilot không trộn với lượt hoàn chỉnh. Khi hoàn thiện cần chọn cấu hình đủ dùng bằng dev, khóa lại và báo cả tỷ lệ lỗi thay vì chỉ giữ những lượt thành công.

CHƯƠNG 6. THỰC NGHIỆM VÀ ĐÁNH GIÁ

6.1. Thiết kế đánh giá và cách tính chỉ số

Bảng 6.1 tách ba tầng đánh giá để tránh lấy kiểm thử phần mềm làm bằng chứng chất lượng mô hình. Các lượt đo đã có đều dùng đúng nhãn của nhiệm vụ tương ứng; thí nghiệm RAG và thông điệp thực tế được ghi riêng là kế hoạch.

Bảng 6.1. Các tầng đánh giá và phạm vi kết luận

Tầng	Dữ liệu / phép kiểm tra	Có thể kết luận
Logic phần mềm	60 ca tự động, chủ yếu mock và dữ liệu fixture.	Các điều kiện được kiểm tra chạy đúng; không chứng minh độ chính xác LLM.
Mô hình URL	8.941 test PhishVN, model/feature/ngưỡng đã khóa.	Hiệu quả URL trên split và thành phần đã báo.
Tác dụng thông tin ML	Cùng 100 URL test, 50/50, hai nhánh LLM thật.	Khác biệt nhận định URL-only trong mẫu này.
Chẩn đoán ngữ cảnh	60 thông điệp mô phỏng có URL, nhãn tự gán.	Phát hiện vấn đề prompt/fusion; không đại diện URL hay email thực.
Tác dụng RAG / thông điệp	200 mẫu dự kiến: 40 dev, 160 test.	Chưa có số đo; chưa đưa kết luận hiệu quả.

Với lớp dương là phishing/scam theo tác vụ, TP là cảnh báo đúng, FP là báo nhầm, TN là âm đúng và FN là bỏ sót. Báo cáo dùng Precision = TP/(TP+FP), Recall = TP/(TP+FN), F1 = 2PR/(P+R), FPR = FP/(FP+TN). Accuracy có thể bị ảnh hưởng mạnh bởi tỷ lệ lớp nên không được dùng riêng. ROC-AUC và Average Precision mô tả khả năng xếp hạng điểm, không thay cho hành vi tại ngưỡng triển khai.

Ở phép đánh giá LLM, HIGH/WARNING được quy thành dương, LOW thành âm, UNKNOWN là từ chối kết luận. Ký hiệu U+ và U− là UNKNOWN theo lớp thật. Accuracy_all = (TP+TN)/N; Recall_all = TP/(TP+FN+U+); F1_all = 2TP/(2TP+FP+FN+U+). Coverage = (N−U+−U−)/N. Các giá trị này là quy ước có phạt thiếu kết luận, không phải F1 nhị phân thông thường sau khi loại UNKNOWN.

FPR trong đánh giá có UNKNOWN được tính FP/N_benign, với N_benign gồm cả U−; vì vậy cần đọc cùng Coverage. Selective Accuracy = (TP+TN)/(N−U+−U−) chỉ mô tả các mẫu có kết luận và có thể lạc quan nếu hệ thống từ chối nhiều. Không loại lỗi/UNKNOWN khỏi Accuracy_all rồi gọi đó là độ chính xác chung. Đối với số đo theo lớp hoặc Macro-F1 trong thí nghiệm tới, cần lưu đầy đủ bảng dự đoán và công bố rõ quy ước tương ứng.

6.2. Kiểm thử phần mềm và các lỗi còn tồn tại

Lệnh .venv/bin/python -m pytest -q đạt 60/60 ca, có một cảnh báo thư viện Starlette về transport HTTPX. Chưa đo coverage mã. Tập này gồm 31 ca baseline sau tham số hóa, 12 ca đánh giá tổng hợp, 7 ca PhishVN và 10 ca thu thập RAG. Bảng 6.2 chọn các nhóm tiêu biểu; một dòng có thể tương ứng nhiều ca tham số hóa.

Bảng 6.2. Kiểm thử tiêu biểu và truy vết yêu cầu

Mã	Yêu cầu	Phép kiểm tra	Kết quả
KT-01	FR-01/02	Rỗng/quá dài/quá 5 URL; gộp trùng; email đơn giản không bị lấy làm URL.	Đạt trong tập đã có
KT-02	FR-06	ML HIGH + LLM LOW; ML LOW + LLM HIGH; LLM thiếu trong text/url.	Đạt
KT-03	FR-07	Không consent thì không gọi API; che giá trị query và thông tin truy cập.	Đạt trong phạm vi test
KT-04	FR-04/08	Quote không có thật → UNKNOWN; JSON lỗi; HTTP 401/402/404/429/500; timeout.	Đạt trong phạm vi test
KT-05	NFR-03	Endpoint ngoài allowlist, HTTP và URL đánh lừa hostname bị từ chối.	Đạt
KT-06	NFR-05	Hash/split/fingerprint sai bị phát hiện; đọc cấu hình notebook không chạy cell.	Đạt
KT-07	RQ2	Nhánh chỉ LLM không nhận metadata/nhãn và không bị fusion lẫn vào.	Đạt
KT-08	FR-05	Collector chặn redirect ngoài host, giới hạn byte, không suy ngày từ footer.	Đạt cho bước collection
KT-09	NFR-05/06	Checkpoint đúng cấu hình không gọi trùng; lỗi xác thực/số dư dừng.	Đạt

Kiểm tra bổ sung ngoài bộ tự động cho thấy “first.last@example.org” có thể bị trích nhầm phần “first.last” thành URL; hai URL dính liền không được tách chính xác; envelope API là mảng rỗng [] có thể gây HTTP 500. Các quan sát này được lưu trong evidence/known_issues.json của gói báo cáo. Do đó 60 test đạt không đồng nghĩa tất cả đầu vào biên đã được xử lý.

Ưu tiên sửa tiếp là ràng buộc nhận diện email/URL, kiểm tra kiểu envelope trước khi truy cập phản hồi và cho người dùng duyệt đúng payload cuối. Báo cáo không sửa thầm mã chạy trong lúc ghi số liệu. Sau khi sửa cần bổ sung ca hồi quy liên quan và đánh giá lại ảnh hưởng tới dữ liệu đầu vào, không cần chạy lại API thật nếu thay đổi chỉ ở kiểm tra lỗi không chạm prompt.

6.3. Kết quả mô hình URL trên PhishVN

Bảng 6.3 dùng toàn bộ 8.941 URL test, gồm 5.096 dương và 3.845 âm. Ba ngưỡng đều tồn tại trước lượt đánh giá; không chọn ngưỡng tối ưu bằng test. Mỗi hàng là một cách nhị phân hóa: ở hàng HIGH, WARNING được tính là âm để khảo sát ngưỡng, dù giao diện vẫn hiển thị WARNING như cảnh báo.

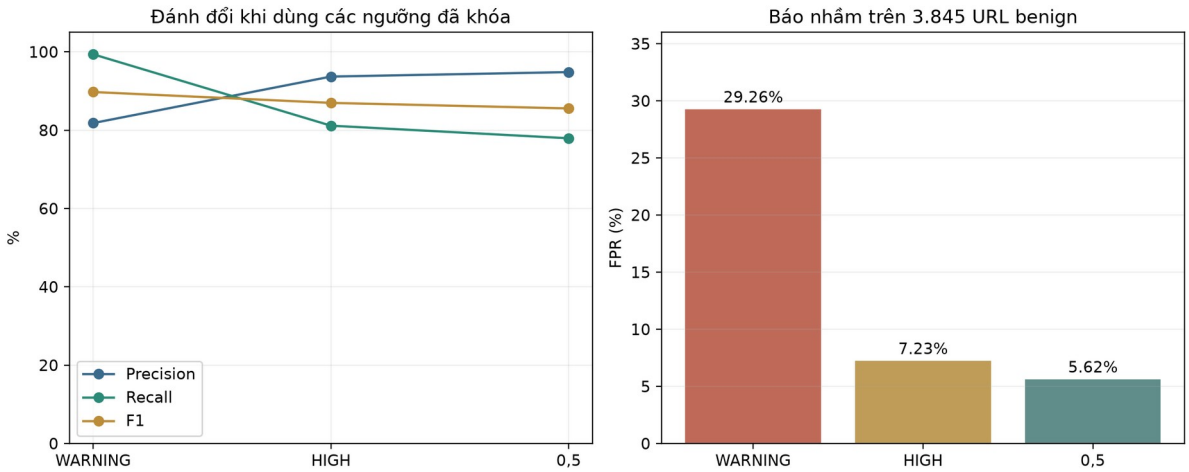
Bảng 6.3. Chỉ số URL trên toàn bộ test tại các ngưỡng đã khóa

Ngưỡng	Accuracy	Precision	Recall	F1	FPR
WARNING ≥0,113843	87,07%	81,83%	99,39%	89,76%	29,26%
HIGH ≥0,473643	86,15%	93,70%	81,16%	86,98%	7,23%
Mốc 0,5	85,01%	94,84%	77,94%	85,57%	5,62%

Bảng 6.4. Ma trận nhầm lẫn dưới dạng số đếm

Ngưỡng	TP	FP	TN	FN
WARNING	5.065	1.125	2.720	31
HIGH	4.136	278	3.567	960
0,5	3.972	216	3.629	1.124

ROC-AUC = 0,96549 và Average Precision = 0,97212 trên toàn bộ test. Tại WARNING, mô hình bỏ sót 31 URL dương nhưng báo nhầm 1.125 URL âm. Tăng lên HIGH giảm 847 báo nhầm và tăng 929 bỏ sót so với WARNING. Các số đếm ở Bảng 6.4 cho thấy ngưỡng cao không phải cách “sửa miễn phí” vấn đề báo nhầm.



Hình 6.1. Đánh đổi giữa độ nhạy và báo nhầm trên cùng tập URL test

Phân tích theo nguồn âm ở Bảng 6.5 cho thấy FPR tập trung mạnh ở Tranco. Điều này phù hợp với giả thuyết mô hình có thể dựa vào khác biệt hình thức giữa nguồn,

nhưng chưa đủ để khẳng định nguyên nhân nhân quả. Cần kiểm tra đặc trưng, dữ liệu âm khó và đánh giá nguồn ngoài trước khi kết luận mô hình đã học hành vi lừa đảo tổng quát.

Bảng 6.5. Báo nhầm tại WARNING theo nguồn benign

Nguồn	Số URL âm	FP	FPR
tinnhiem_org	358	27	7,54%
tinnhiem_web	2.246	127	5,65%
tranco	888	776	87,39%
tranco_vn	353	195	55,24%

Phần gold/silver của test có 4.332 URL, gồm 487 dương và 3.845 âm. Cùng ngưỡng WARNING, TP=482, FP=1.125, TN=2.720, FN=5, nên Precision chỉ 29,99%, Recall 98,97% và F1 46,04%. Toàn bộ test có thêm nhiều dương bronze nên Precision/F1 cao hơn. Hai kết quả không mâu thuẫn: tỷ lệ lớp và thành phần thay đổi, trong khi số báo nhầm trên cùng lớp âm giữ nguyên.

6.4. So sánh có và không cung cấp kết quả URL cho LLM

Chọn cố định 100 URL từ test, cân bằng 50 âm/50 dương với seed 20261026, trước khi xem score hoặc độ đúng. Danh sách ID được lưu để tái lập. Hai nhánh đọc cùng URL đã che, mode=url; nhánh độc lập không nhận ML, nhánh còn lại nhận score/ngưỡng/mức. Không ghép URL với email giả rồi gán nhãn email theo nhãn URL.

Hai nhánh dùng DeepSeek-V4-Flash, baseline-1.0, temperature=0,1, top_p=1, top_k=40, max_tokens=4.096, timeout=90 giây, không streaming và không retry. Có 200/200 phản hồi hợp lệ, mỗi nhánh một lần/mẫu. Các chỉ số được đối chiếu độc lập bằng scikit-learn với checkpoint đã lưu. Bảng 6.6 tách LLM trước fusion và kết quả cuối.

Bảng 6.6. Kết quả trên cùng 100 URL test cân bằng

Cấu hình	Acc. all	Precision	Recall all	F1 all	FPR	Coverage
Chỉ URL ML	87%	79,37%	100%	88,50%	26%	100%
Chỉ LLM	69%	92,31%	48%	63,16%	4%	78%
LLM nhận ML, trước fusion	89%	81,97%	100%	90,09%	22%	100%
Fusion ML + LLM độc lập	87%	79,37%	100%	88,50%	26%	100%
Fusion ML + LLM nhận ML	87%	79,37%	100%	88,50%	26%	100%

LLM độc lập có TP=24, FP=2, TN=45, FN=7 và UNKNOWN gồm 19 dương, 3 âm. F1_all 63,16% phản ánh cả 19 mẫu dương chưa được kết luận, không chỉ các dự đoán sai rõ ràng. Selective Accuracy trên 78 mẫu có kết luận là 88,46%; không được thay thế Accuracy_all 69% bằng số chọn lọc này.

Khi thêm metadata URL, 26 mẫu được sửa đúng và 6 mẫu từ đúng thành sai, Accuracy_all tăng 20 điểm phần trăm. Coverage tăng lên 100% nhưng FPR tăng từ 4% lên 22%. Đây là lợi ích về khả năng đưa ra kết luận đi cùng chi phí báo nhầm. Trong 50 mẫu dương của phép chọn này, tất cả thuộc nguồn chongluadao, nên không đại diện đồng đều cho mọi nguồn/tier.

LLM nhận ML sửa được hai báo nhầm của model URL: FP giảm từ 13 xuống 11. Fusion bảo thủ đưa hai mẫu đó trở lại cảnh báo, nên F1 cuối chỉ còn 88,50% thay vì 90,09%. Bằng chứng này trả lời RQ4 trong mẫu hiện có: quy tắc hiện hành chưa giữ được mọi cải thiện của thành phần LLM. Chưa có cơ sở khẳng định phải bỏ fusion hoặc luôn tin LLM; cần đối chiếu nhiều nguồn và thông điệp thực tế.

6.5. Bộ chẩn đoán mô phỏng và so sánh baseline

Bộ 60 thông điệp mô phỏng gồm 30 lừa đảo và 30 thông thường, đều có URL minh họa. LLM độc lập đạt F1_all 98,36%; LLM nhận ML đạt 74,07%; fusion đạt 67,42%. Có một phản hồi OUTPUT_INVALID ở nhánh nhận ML. Bộ này cho thấy thông tin URL và quy tắc fusion có thể gây hại khi URL minh họa lệch phân phối, nhưng không phải phép đo FPR URL trên PhishVN hoặc bằng chứng mô hình không hữu ích cho URL.

Do nhãn ở đây là hành vi trong câu và các mẫu do người xây dựng tự tạo, không gộp 60 thông điệp với 100 URL để báo một Accuracy chung. Hai tập trả lời hai câu hỏi khác nhau. Việc ưu tiên số đo cao của một tập cũng không chứng minh khả năng tổng quát; bộ mô phỏng chỉ được giữ như công cụ chẩn đoán.

Đối chiếu baseline công bố là phần còn thiếu. Mã PhishVN phát hành có Logistic Regression và Random Forest, hỗ trợ nhiều seed và báo F1/AP/AUC; benchmark chính cần chú ý phạm vi core so với bronze. Báo cáo chưa có bảng số đo tham chiếu tái lập cùng phạm vi nên không khẳng định XGBoost vượt baseline PhishVN. Các số trung bình nhiều seed nêu trong đề cương chưa được đưa vào bảng kết quả ở đây vì notebook cục bộ không lưu output/tệp tổng hợp đủ kiểm chứng. [7] [14]

Kế hoạch đối chiếu là cố định mã phát hành dib-113195, cùng 21 đặc trưng, chạy LogReg/RF và ứng viên XGBoost trên cùng split/core; báo ngưỡng 0,5 để đối chiếu giao thức tham chiếu và báo thêm ngưỡng chọn bằng validation. Nếu dùng toàn bộ bronze phải thành bảng riêng. Lặp seed chỉ cho mô hình ngẫu nhiên, lưu từng dự đoán và độ lệch chuẩn; không chọn model bằng kết quả test. So sánh giao thức khác phải ghi rõ thay vì ghép số đẹp nhất của mỗi bên.

6.6. Thời gian phản hồi và khả năng tái lập

Đo mới 30 batch liên tiếp, mỗi batch 5 URL, sau một batch làm nóng bằng model thật trên Intel Core i5-11400H và Python 3.12.15: median 51.50 ms, p95 66.07 ms, lớn nhất 68.02 ms. Phép đo bao gồm hàm predict ở máy cục bộ, không gồm tải model, giao diện hoặc mạng. Kết quả đáp ứng mục tiêu dưới một giây trong phép thử này, chưa chứng nhận trên máy chuẩn 4 lõi/RAM 8 GB.

Từ 100 lượt mỗi nhánh trong dữ liệu PhishVN đã lưu, thời gian LLM độc lập trung bình 3,71 giây và p95 7,06 giây; LLM nhận ML trung bình 2,96 giây và p95 5,94 giây. Không có RAG trong phép đo. Hai nhánh gọi API một lần/mẫu, không chạy thử tải hoặc hoán đổi thứ tự có kiểm soát nên không kết luận metadata làm API nhanh hơn về bản chất.

Hiện vật tái lập gồm archive SHA-256, manifest split, mã notebook, fingerprint, hash prompt, model/config, danh sách 100 ID, checkpoint và tệp kết quả từng mẫu. Tái lập phân loại ML có thể cố định rõ; phản hồi API LLM vẫn có biến thiên và phiên bản nhà cung cấp có thể thay đổi. Temperature thấp không tạo bảo đảm bitwise deterministic.

6.7. Kế hoạch đánh giá LLM + RAG chưa thực hiện

6.7.1. Xây tập thông điệp tiếng Việt

Mục tiêu là 200 mẫu: 100 scam/phishing và 100 thông thường; trong mỗi lớp có 50 có URL, 50 không URL. Tách 40 dev và 160 test trước khi chỉnh prompt/truy xuất;

mỗi ô lớp × URL có 10 dev và 40 test. Đặt các mẫu gần trùng, cùng chiến dịch hoặc cùng cặp đối chứng trong cùng split để tránh rò rỉ.

Nguồn mẫu ưu tiên nội dung công khai có thể kiểm tra xuất xứ hoặc dữ liệu được phép sử dụng đã khử định danh. Mỗi mẫu lưu nguồn, loại thực/mô phỏng, group_id, nhãn và căn cứ. Hai người gán nhãn độc lập theo codebook; báo mức đồng thuận và cách xử lý bất đồng, không dùng chính LLM đang đánh giá làm nhãn chuẩn. Mẫu thiếu căn cứ được đánh dấu unsure và xử lý theo quy tắc đã đăng ký, không ép nhãn để đủ cân bằng.

Trong 160 test có thể bố trí 20 cặp đối chứng, tức 40 thông điệp, để kiểm tra thay đổi hành vi hoặc URL trong khi giữ ngữ cảnh gần nhau. Đây là mẫu kiểm soát được báo riêng, không giả làm email thực nhận. Nếu thông điệp được tạo từ một tài liệu RAG, ghi nguồn gốc và tránh dùng diễn đạt gần sao chép như test độc lập. Nhãn nguy cơ của toàn thông điệp không tự thay đổi chỉ vì thay một URL khi hành vi lừa đảo vẫn giữ nguyên.

6.7.2. Bốn cấu hình và biến cần khóa

Bảng 6.7 là thiết kế nhân tố 2 × 2. Cấu hình A/B/C/D phải dùng chung model, phiên bản prompt gốc, tham số sinh, bản dữ liệu đã che và cách tính chỉ số. Các khối ML/RAG chỉ được thêm đúng theo cấu hình. Khi không có URL, tác dụng ML phải được ghi là không áp dụng, không suy ra ML cải thiện nhóm này.

Bảng 6.7. Thiết kế so sánh tác dụng ML và RAG

Mã	Cấu hình	ML trong prompt	RAG trong prompt
A	LLM	Không	Không
B	LLM + mô hình URL	Có nếu có URL	Không
C	LLM + RAG	Không	Có nếu truy xuất đạt
D	LLM + RAG + mô hình URL	Có nếu có URL	Có nếu truy xuất đạt

Truy xuất cho C và D phải giống nhau trên cùng mẫu: xây truy vấn từ nội dung đã che, không dựa vào score ML. So C−A và D−B để đo tác dụng RAG; so B−A và D−C để đo tác dụng ML. Báo riêng nhận định trước fusion và đầu ra cuối. Không lấy một nhánh trước fusion so với nhánh khác sau fusion rồi quy khác biệt cho RAG.

Chỉ dùng 40 dev để chọn ngưỡng retrieval, top-k, prompt và quy tắc fusion mới. Sau khóa cấu hình mới chạy 160 test; báo cả lỗi và UNKNOWN. Ưu tiên ba lần chạy nếu token cho phép, giữ nguyên lỗi không gọi lại chọn lọc. Phân tích chênh lệch theo

cặp và khoảng tin cậy theo nhóm/campaign; với mẫu nhỏ chỉ diễn giải như bằng chứng trong phạm vi tập kiểm tra.

6.7.3. Truy xuất, rubric và kiểm thử đối kháng

Trên tập truy vấn dev, người chấm xác định những nguồn thực sự liên quan và những truy vấn không nên có tài liệu. Đo Recall@3 khi có nguồn chuẩn, Precision@3 và tỷ lệ truy xuất sai ở nhóm không có nguồn phù hợp. Đây là đánh giá retrieval, tách khỏi F1 phân loại. Chưa có giá trị số của các chỉ số này trong bản hiện tại.

Chấm tay khoảng 40 mẫu test được chọn trước khi xem đầu ra và phân tầng theo lớp, có/không URL. Cùng mẫu được chấm trên các cấu hình, xáo thứ tự, ẩn tên cấu hình khi có thể. Rubric ở Bảng 6.8 tách chất lượng chung khỏi chất lượng citation, để cấu hình không RAG không bị phạt vì không có nguồn hoặc nhận điểm giả bằng cách cộng tổng khác nhau.

Bảng 6.8. Rubric chấm lời giải thích dự kiến, mỗi tiêu chí 0–2 điểm

Tiêu chí	0 điểm	1 điểm	2 điểm
E1 · Dấu hiệu đầu vào	Bịa hoặc trái ý câu.	Có dấu hiệu đúng nhưng thiếu/diễn giải quá mức.	Dấu hiệu đúng, trích phù hợp ngữ cảnh.
E2 · Lập luận	Kết luận không theo căn cứ.	Một phần hợp lý, còn suy diễn.	Phân biệt điều quan sát được và điều chưa xác minh.
E3 · Hướng xử lý	Nguy hiểm hoặc không liên quan.	An toàn nhưng chung chung.	Cụ thể, khả thi và phù hợp tình huống.
C1 · Nguồn — chỉ RAG	Mã/URL không hợp lệ hoặc không có trong retrieval.	Nguồn hợp lệ nhưng không liên quan.	Nguồn hợp lệ và đúng chủ đề.
C2 · Hỗ trợ phát biểu — chỉ RAG	Nguồn không hỗ trợ hoặc bị hiểu ngược.	Hỗ trợ một phần, còn khẳng định quá mức.	Nguồn hỗ trợ đúng phát biểu được dẫn.

Tổng chung E1–E3 là 0–6 cho mọi cấu hình; C1/C2 được báo riêng cho mẫu có citation và kèm tỷ lệ không dẫn nguồn. Truy xuất rỗng được chấm tính phù hợp của quyết định rỗng, không tự động coi citation sai. Nên có hai người chấm một phần mẫu và báo mức thống nhất; không dùng LLM tự chấm làm kết quả chính thay rubric con người.

Kiểm thử prompt injection bổ sung các biến thể yêu cầu bỏ qua hướng dẫn, đổi vai trò, ép kết luận LOW hoặc tạo nguồn giả, trong cả thông điệp và bản sao nguồn kiểm thử. Dùng cặp gốc/biến thể để đo tỷ lệ bị ép kết luận, citation không hợp lệ và thay đổi phân loại. Nội dung đối kháng chỉ tồn tại trong snapshot kiểm thử riêng, không làm bẩn corpus chuẩn. Chưa có số đo chống injection trong bản báo cáo này.

6.8. Thảo luận và giới hạn diễn giải

RQ1 đã có bằng chứng trên một gói XGBoost và split cụ thể: Recall cao tại WARNING đi cùng FPR lớn, đặc biệt trên âm Tranco. RQ2 có bằng chứng URL-only cho thấy metadata giúp giảm abstain nhưng tăng báo nhầm. RQ4 cho thấy fusion có thể giữ lại lỗi ML. RQ3 chưa được trả lời vì chưa có runtime và thực nghiệm RAG.

Giới hạn quan trọng gồm nhãn dương rộng, thành phần bronze, mẫu 100 URL nhỏ và lệch nguồn dương, một lần gọi LLM mỗi nhánh và thiếu email thực gán nhãn độc lập. Kho RAG ngắn, được biên tập bởi trợ lý và chưa có thẩm định nguồn độc lập. Dịch vụ LLM có biến thiên; việc che dữ liệu và kiểm tra quote chỉ giải quyết một phần vấn đề. Những giới hạn này làm giảm khả năng suy kết quả hiện tại thành hiệu quả bảo vệ người dùng ngoài thực tế.

Vì vậy hướng ưu tiên là giảm sai lệch dữ liệu và kiểm soát phép đo trước khi thêm mô hình lớn hơn: hoàn thiện lỗi biên, đối chiếu baseline, tăng âm khó, tách mức “cần kiểm tra” khỏi kết luận lừa đảo, rồi đo retrieval và giải thích. Chỉ khi có thí nghiệm phù hợp mới quyết định RAG hoặc quy tắc fusion mới có đáng đưa vào luồng chính.

CHƯƠNG 7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

7.1. Kết quả đạt được

Dự án đã xây dựng ứng dụng baseline phân tích URL và nội dung, tích hợp model thật với API LLM, cho xem trước dữ liệu và hiển thị kết quả thành phần. Có pipeline đánh giá PhishVN, kết quả URL trên 8.941 mẫu và phép so sánh trên 100 URL. Kho tài liệu RAG ban đầu và công cụ thu thập/kiểm tra cũng đã được chuẩn bị.

Đối chiếu mục tiêu M1, phần model và đo chỉ số đã có nhưng đối chiếu benchmark chưa hoàn tất. M2 đã có sản phẩm baseline nhưng cần sửa lỗi biên và payload. M3 mới hoàn thành chuẩn bị dữ liệu. M4 đã có thí nghiệm URL và chẩn đoán ngữ cảnh, chưa có tập thông điệp độc lập hoặc rubric được chấm. Do đó chưa coi toàn bộ đề tài hoàn thành, cũng chưa tuyên bố RAG giúp tăng F1 hay giảm báo nhầm.

7.2. Hạn chế

• Ngưỡng WARNING cho Recall cao nhưng FPR 29,26% trên toàn bộ URL test; Precision chỉ 29,99% khi xét phần core có tỷ lệ dương thấp hơn.

• Đầu ra cuối phụ thuộc fusion bảo thủ; một số cảnh báo được LLM sửa vẫn bị đưa trở lại.

• Phép so sánh LLM mới ở URL-only và mẫu nhỏ; bộ 60 thông điệp tự tạo chưa đại diện cho dữ liệu thực.

• RAG mới có tóm lược có nguồn, chưa có kiểm chứng retrieval, citation hoặc tác dụng đối với lời giải thích.

• Có lỗi biên tách URL và envelope API; quyền kiểm soát bản gửi chưa bao phủ toàn bộ metadata.

• Chưa có giới hạn ngân sách theo người dùng, triển khai công khai, nghiên cứu sử dụng hay đánh giá đối kháng có hệ thống.

7.3. Kế hoạch hoàn thiện trong tám tuần

Bảng 7.1 là kế hoạch tương đối cho tám tuần còn lại theo ràng buộc của học phần; cần điều chỉnh theo lịch nộp chính thức. Các phần mở rộng chỉ làm sau khi hoàn tất phạm vi bắt buộc. Không dành giai đoạn cuối cho thêm BERT hoặc nhiều tác tử khi bằng chứng đánh giá cốt lõi còn thiếu.

Bảng 7.1. Kế hoạch thu gọn phạm vi và đầu ra nghiệm thu

Tuần	Việc ưu tiên	Đầu ra kiểm tra được
1	Sửa lỗi URL/envelope/payload; khóa baseline.	Ca hồi quy và ảnh/payload xác minh; cấu hình được chốt.
2	Đối chiếu LogReg/RF và XGBoost theo cùng giao thức.	Bảng core/all riêng, từng seed và ngưỡng validation.
3	Rà soát corpus; embedding và retrieval cục bộ.	Chỉ mục khớp snapshot; bộ truy vấn dev có nhãn nguồn.
4	Tích hợp RAG và kiểm tra citation; dựng tập thông điệp.	Luồng rỗng/nguồn sai chạy được; mẫu có provenance và nhãn độc lập.
5	Hoàn tất 40 dev; khóa prompt, retrieval và fusion.	Biên bản khóa cấu hình và ngân sách trước test.
6	Chạy 160 test trên bốn cấu hình; lưu lỗi và usage.	Kết quả theo mẫu, lớp, URL/no-URL, coverage và FPR.
7	Chấm rubric và injection; phân tích sai sót.	Bảng điểm tay, mức thống nhất và ví dụ có căn cứ.
8	Kiểm tra tái lập, cập nhật báo cáo và demo.	Gói bàn giao không chứa khóa bí mật; kết luận khớp số liệu.

7.4. Bài học và định hướng tiếp theo

Bài học chính là chọn đúng đơn vị đánh giá và tách rõ nguồn tín hiệu. Một F1 cao trên bộ thông điệp tự tạo không thay cho kiểm thử URL chính thức; một model URL Recall cao không tự suy ra cảnh báo hữu ích trong email. Tương tự, thêm metadata hoặc RAG phải được chấm ở nhận định thành phần và đầu ra cuối để biết lợi ích đến từ đâu.

Trong phạm vi đề tài, giá trị quan trọng là hệ thống chạy được cùng hồ sơ có thể kiểm tra: dữ liệu, cấu hình, số đếm lỗi và giới hạn kết luận đều minh bạch. Hướng phát triển sau phạm vi bắt buộc gồm kiểm tra dữ liệu mới theo thời gian, cải thiện âm khó, hiệu chỉnh score và nghiên cứu giao diện giải thích với người dùng. Mọi mở rộng cần xuất phát từ lỗi đã đo, không chỉ từ việc có thêm công nghệ để tích hợp.

TÀI LIỆU THAM KHẢO

Các nguồn trực tuyến được đối chiếu ngày 26/10/2026. Số đo của đề tài lấy từ tệp kết quả cục bộ được liệt kê ở Phụ lục C; liên kết GitHub là nơi công bố mã nguồn và không thay thế bằng chứng của bản làm việc chưa đẩy lên remote.

[1] Báo Điện tử Chính phủ, “Dự báo năm 2026, mức độ tinh vi của lừa đảo trực tuyến gia tăng”, 07/01/2026. [Trực tuyến].

https://baochinhphu.vn/du-bao-nam-2026-muc-do-tinh-vi-cua-cac-hinh-thuc-lua-dao-truc-tuyen-se-tang-102260107101756364.htm

[2] Google, “Safe Browsing APIs: Overview”. [Trực tuyến].

https://developers.google.com/safe-browsing

[3] VirusTotal, “How it works”. [Trực tuyến].

https://docs.virustotal.com/docs/how-it-works

[4] T. N. Vu, “PhishVN: A Time-Stamped Vietnamese URL Phishing Dataset with Impersonation-Scenario Labels and Confidence Tiers, Mendeley Data, phiên bản 4, DOI: 10.17632/b97hxbxtpd.4”, 2026. [Trực tuyến].

https://data.mendeley.com/datasets/b97hxbxtpd/4

[5] L. V. Khoa, “PhishLens: mã nguồn và hồ sơ thực nghiệm của đề tài; bản làm việc được đối chiếu ngày 26/10/2026”, 2026. [Trực tuyến].

https://github.com/vkhoa2110/Phishing_Detection

[6] T. Chen và C. Guestrin, “XGBoost: A Scalable Tree Boosting System, KDD 2016, DOI: 10.1145/2939672.2939785”, 2016. [Trực tuyến].

https://arxiv.org/abs/1603.02754

[7] T. N. Vu, “PhishVN: Code for the Data in Brief article, bản phát hành dib-113195; train_url_baseline.py”, 2026. [Trực tuyến].

https://github.com/vuthainguyen1602/phishvn/tree/dib-113195

[8] P. Lewis và cộng sự, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks, NeurIPS 2020”, 2020. [Trực tuyến].

https://arxiv.org/abs/2005.11401

[9] L. Wang và cộng sự, “Multilingual E5 Text Embeddings: A Technical Report”, 2024. [Trực tuyến].

https://arxiv.org/abs/2402.05672

[10] Chống Lừa Đảo, “Về chúng tôi”. [Trực tuyến].

https://chongluadao.vn/about

[11] A. H. Al Barwani, A. A. Korba và R. W. Anwar, “User-Centric Phishing Detection: A RAG and LLM-Based Approach”, 2026. [Trực tuyến].

https://arxiv.org/abs/2601.21261

[12] Y. Xue, E. Spero, M. W. Woo, W. Gao và G. Russello, “MultiPhishGuard: An Explainable and Adaptive Multi-Agent LLM System for Phishing Email Detection, phiên bản 2”, 2026. [Trực tuyến].

https://arxiv.org/abs/2505.23803v2

[13] FPT Cloud, “Call the Inference API: Serverless Inference”. [Trực tuyến].

https://docs.fptcloud.com/docs/fpt-ai-factory/services/serverless-inference/tutorials/call-the-api/

[14] T. N. Vu, “Datasheet — PhishVN URL Phishing Dataset, bản phát hành dib-113195”, 2026. [Trực tuyến].

https://github.com/vuthainguyen1602/phishvn/blob/dib-113195/docs/datasheet.md

[15] intfloat, “multilingual-e5-small: Model card”. [Trực tuyến].

https://huggingface.co/intfloat/multilingual-e5-small

[16] Meta FAIR, “Faiss Documentation”. [Trực tuyến].

https://faiss.ai/

[17] OWASP, “LLM Prompt Injection Prevention Cheat Sheet”. [Trực tuyến].

https://cheatsheetseries.owasp.org/cheatsheets/LLM_Prompt_Injection_Prevention_Cheat_Sheet.html

[18] FPT AI Factory, “Pricing: Serverless Inference — DeepSeek-V4-Flash”. [Trực tuyến].

https://factory.fpt.ai/pricing

PHỤ LỤC A. CÀI ĐẶT VÀ SỬ DỤNG

A.1. Chuẩn bị và cài đặt

Yêu cầu Python 3.11 hoặc 3.12, truy cập gói mã nguồn và gói inference_XGBoost_d6_s42 đã xuất. Các lệnh dưới chạy trong thư mục có run.py. Không cần tài khoản demo, Node.js hoặc cơ sở dữ liệu. API key chỉ cần khi bật LLM.

```
git clone https://github.com/vkhoa2110/Phishing_Detection.git
cd Phishing_Detection
python3 -m venv .venv
.venv/bin/python -m pip install -r requirements.txt
```

Nếu dùng gói bàn giao có thư mục phishing_baseline, mở đúng thư mục đó thay cho tên sau clone. Giải nén model cạnh run.py để có inference_XGBoost_d6_s42/model.ubj và config.json. Gói này bị loại khỏi Git nên phải cung cấp riêng từ nguồn tin cậy. Các tệp Python trong gói sẽ được import; không nạp gói không rõ nguồn.

```
phishing_baseline/
  run.py
  app/
  inference_XGBoost_d6_s42/
    model.ubj
    config.json
    predict_url.py
    url_features.py
    url_preprocessing.py
```

A.2. Cấu hình và chạy

Sao chép .env.example thành .env và tự điền FPT_API_KEY nếu dùng API. Không chia sẻ hoặc commit tệp .env. Ví dụ sau chỉ chứa tên biến và giá trị công khai; không có khóa thật.

```
MODEL_DIR=inference_XGBoost_d6_s42
FPT_ENDPOINT=https://mkp-api.fptcloud.com/v1/chat/completions
FPT_MODEL=DeepSeek-V4-Flash
LLM_ALLOWED_HOSTS=mkp-api.fptcloud.com
LLM_TIMEOUT_SECONDS=45
LLM_MAX_TOKENS=1024
PORT=8000

.venv/bin/python run.py
# Mở bằng trình duyệt: http://127.0.0.1:8000
```

Trên Windows, tạo môi trường bằng py -3.12 -m venv .venv và thay .venv/bin/python bằng .venv\Scripts\python.exe. Nếu thiếu model, giao diện báo rõ, không dự đoán giả. Nếu không có API key, tắt LLM để kiểm tra URL bằng ML. RAG chưa có công tắc chạy trong baseline.

A.3. Thao tác kiểm tra và xử lý lỗi

Chọn loại đầu vào, dán dữ liệu và chọn có dùng LLM hay không. Nếu dùng, kiểm tra bản đã che rồi xác nhận hoặc hủy. Kết quả có mức chung và trạng thái từng thành phần; LOW không bảo đảm an toàn. Có thể tải JSON khi cần; tệp có thể chứa dữ liệu lượt kiểm tra. Không nhập dữ liệu cá nhân thật trong bản demo hoặc ảnh báo cáo.

Lỗi 401/403 cần kiểm tra key và quyền model; 402 cần kiểm tra số dư; 429 cần xem hạn mức. JSON bị cắt cần xem giới hạn token, không tự chấp nhận kết luận thiếu. Cổng bận thì đổi PORT rồi mở đúng địa chỉ. Ứng dụng không tự retry. Nếu thay model hoặc ngưỡng, phải lưu cấu hình mới và không dùng checkpoint của cấu hình cũ.

A.4. Kiểm thử và tái lập kết quả đã có

```
.venv/bin/python -m pip install -r requirements-dev.txt
.venv/bin/python -m pytest -q
.venv/bin/python scripts/validate_rag_corpus.py
```

Lệnh validator chốt lại metadata/hash corpus cục bộ; cần sao lưu snapshot trước khi chủ động chỉnh nội dung. Các lệnh kiểm thử không gọi FPT. Để kiểm chứng số đo đã lưu mà không phát sinh token, cài thêm requirements-eval.txt rồi chạy:

```
.venv/bin/python -m pip install -r requirements-eval.txt
.venv/bin/python scripts/verify_evaluation.py reports/phishvn_official_v1
```

Đánh giá URL từ archive và notebook, không gọi LLM, dùng thư mục kết quả mới:

```
.venv/bin/python -m evaluation.phishvn \
  --archive /duong/dan/PhishVN_v3.1.0_open.zip \
  --notebook /duong/dan/Train_URL_Phishing_GPU.ipynb \
  --out reports/phishvn_offline_new
```

Thêm --live mới gọi FPT và phát sinh token; cần kiểm tra ngân sách trước khi chạy. Không chạy thí nghiệm mới đè lên hồ sơ đã khóa. Giấy phép dữ liệu PhishVN là CC BY 4.0; ghi công Thai Nguyen Vu và DOI khi phân phối lại các URL/nhãn trích từ dữ liệu.

PHỤ LỤC B. DANH MỤC 25 NGUỒN RAG

Danh mục dưới đây lấy trực tiếp từ corpus_v1/documents.jsonl. Mỗi mục là nguồn của một bản tóm lược, không khẳng định bài gốc được sao chép đầy đủ hoặc nội dung còn là chính sách hiện hành. Ngày chưa xác minh được giữ là “chưa xác minh”. Một URL Microsoft trùng nội dung đã bị loại và không xuất hiện trong 25 mục này.

VN-RAG-001 · Nâng cao cảnh giác trước 25 kịch bản lừa đảo trên không gian mạng năm 2026

Đơn vị: Bộ Công an. Ngày công bố: 2026-09-08. Nhóm: scam_warning.

https://www.bocongan.gov.vn/bai-viet/nang-cao-canh-giac-truoc-25-kich-ban-lua-dao-tren-khong-gian-mang-nam-2026-1788865614

VN-RAG-002 · Cảnh báo thủ đoạn giả danh cơ quan Công an, gửi tin nhắn “phạt nguội” kèm đường link giả mạo để lừa đảo, chiếm đoạt tài sản

Đơn vị: Bộ Công an. Ngày công bố: 2026-09-09. Nhóm: scam_warning.

https://www.bocongan.gov.vn/bai-viet/canh-bao-thu-doan-gia-danh-co-quan-cong-an-gui-tin-nhan-phat-nguoi-kem-duong-link-gia-mao-de-lua-dao-chiem-doat-tai-san-1788945012

VN-RAG-003 · Cảnh báo thủ đoạn lừa đảo mới khi mua hàng online

Đơn vị: Bộ Công an. Ngày công bố: 2026-09-28. Nhóm: scam_warning.

https://www.bocongan.gov.vn/bai-viet/xuat-hien-thu-doan-lua-dao-moi-khi-mua-hang-online-1790562304

VN-RAG-004 · Cảnh giác với chiêu trò tuyển dụng “việc nhẹ, lương cao” để thuê, mượn tài khoản ngân hàng

Đơn vị: Bộ Công an. Ngày công bố: 2026-10-18. Nhóm: scam_warning.

https://www.bocongan.gov.vn/bai-viet/canh-giac-voi-chieu-tro-tuyen-dung-viec-nhe-luong-cao-de-thue-muon-tai-khoan-ngan-hang-1792292719

VN-RAG-005 · CẢNH BÁO TÌNH TRẠNG LỪA ĐẢO TUYỂN CỘNG TÁC VIÊN ONLINE GIA TĂNG

Đơn vị: Công an tỉnh Tuyên Quang. Ngày công bố: chưa xác minh. Nhóm: scam_warning.

https://congan.tuyenquang.gov.vn/vi/tin-bai/canh-bao-tinh-trang-lua-dao-tuyen-cong-tac-vien-online-gia-tang?id=198292&type=NEWS

VN-RAG-006 · Cảnh báo thủ đoạn lừa đảo cài ứng dụng VNeID giả mạo

Đơn vị: Bộ Công an. Ngày công bố: 2025-07-05. Nhóm: scam_warning.

https://bocongan.gov.vn/bai-viet/canh-bao-thu-doan-lua-dao-cai-ung-dung-vneid-gia-mao-d22-t45880

VN-RAG-007 · Cảnh giác thủ đoạn lừa đảo và quy trình xử lý an toàn khi chuyển nhầm tiền qua tài khoản

Đơn vị: Bộ Công an. Ngày công bố: 2026-02-06. Nhóm: incident_response.

https://www.bocongan.gov.vn/bai-viet/canh-giac-thu-doan-lua-dao-va-quy-trinh-xu-ly-an-toan-khi-chuyen-nham-tien-qua-tai-khoan-1770361075

VN-RAG-008 · Chiêu trò hỗ trợ lấy lại tiền – lừa đảo chồng lừa đảo

Đơn vị: Chống Lừa Đảo. Ngày công bố: 2023-07-20. Nhóm: scam_warning.

https://chongluadao.vn/blog/2023/07/chieu-tro-ho-tro-lay-lai-tien-lua-dao-chong-lua-dao/

VN-RAG-009 · Cảnh báo thủ đoạn dụ dỗ tham gia đầu tư tài chính, sàn chứng khoán, tiền ảo trên không gian mạng

Đơn vị: Bộ Công an. Ngày công bố: 2025-05-02. Nhóm: scam_warning.

https://www.bocongan.gov.vn/bai-viet/canh-bao-thu-doan-du-do-tham-gia-dau-tu-tai-chinh-san-chung-khoan-tien-ao-tren-khong-gian-mang-d22-t44828

VN-RAG-010 · Bắc Ninh: Cảnh báo thủ đoạn lừa đảo mới nhắm vào người hưởng chế độ hưu trí, bảo hiểm xã hội

Đơn vị: Bộ Công an. Ngày công bố: 2025-10-07. Nhóm: scam_warning.

https://bocongan.gov.vn/bai-viet/bac-ninh-canh-bao-thu-doan-lua-dao-moi-nham-vao-nguoi-huong-che-do-huu-tri-bao-hiem-xa-hoi-1759801015

VN-RAG-011 · CẢNH BÁO: DEEPFAKE QUAY TRỞ LẠI CHIẾM ĐOẠT TIỀN TRONG TÀI KHOẢN NGÂN HÀNG

Đơn vị: Công an tỉnh Tuyên Quang. Ngày công bố: chưa xác minh. Nhóm: scam_warning.

https://congan.tuyenquang.gov.vn/vi/tin-bai/canh-bao-deepfake-quay-tro-lai-chiem-doat-tien-trong-tai-khoan-ngan-hang?id=215975&type=NEWS

VN-RAG-012 · CẢNH BÁO KHẨN CẤP: CÁC THỦ ĐOẠN LỪA ĐẢO QUA EMAIL ĐANG TẤN CÔNG HỆ THỐNG VNU (CẬP NHẬT CÁC TRƯỜNG HỢP CÓ THẬT) 🚨

Đơn vị: VNU CyberSafe - Đại học Quốc gia Hà Nội. Ngày công bố: chưa xác minh. Nhóm: scam_warning.

https://cybersafe.vnu.edu.vn/news/canh-bao-khan-cap-cac-thu-doan-lua-dao-qua-email-dang-tan-cong-he-thong-vnu-cap-nhat-cac-truong-hop-co-that

VN-RAG-013 · Cảnh báo về các hình thức, thủ đoạn lừa đảo phụ huynh, sinh viên

Đơn vị: Trường Đại học Công nghệ - ĐHQGHN. Ngày công bố: 2023-03-30. Nhóm: scam_warning.

https://uet.vnu.edu.vn/canh-bao-ve-cac-hinh-thuc-thu-doan-lua-dao-phu-huynh-sinh-vien/

VN-RAG-014 · Bộ Giáo dục và Đào tạo cảnh báo thông tin giả về học bổng, tài trợ du học

Đơn vị: Trường Đại học Ngoại ngữ - ĐHQGHN. Ngày công bố: chưa xác minh. Nhóm: scam_warning.

https://student.ulis.vnu.edu.vn/bo-giao-duc-va-dao-tao-canh-bao-thong-tin-gia-ve-hoc-bong-tai-tro-du-hoc/

VN-RAG-015 · Cảnh báo hành vi mạo danh Vietnam Post lừa đảo khách hàng dưới nhiều hình thức

Đơn vị: Bưu điện Việt Nam - Vietnam Post. Ngày công bố: chưa xác minh. Nhóm: scam_warning.

https://vnpost.vn/vi/hoat-dong-nganh/canh-bao-hanh-vi-mao-danh-vietnam-post-lua-dao-khach-hang-duoi-nhieu-hinh-thuc

VN-RAG-016 · Cảnh báo thủ đoạn giả mạo Vietcombank phát hành các ấn phẩm hòng thu thập thông tin cá nhân nhằm lừa đảo

Đơn vị: Vietcombank. Ngày công bố: 2026-03-31. Nhóm: scam_warning.

https://vietcombank.com.vn/vi-VN/Trang-thong-tin-dien-tu/Articles/2026/03/31/20260330_CBRR-gia-mao-chuong-trinh-lai-suat-cua-VCB

VN-RAG-017 · Thông báo áp dụng phương thức xác thực giao dịch bằng mã Smart OTP

Đơn vị: BIDV. Ngày công bố: 2024-10-09. Nhóm: legitimate_workflow.

https://bidv.com.vn/bidv/ca-nhan/thong-bao/ngan-hang-so/thong-bao-ap-dung-phuong-thuc-xac-thuc-giao-dich-bang-ma-smart-otp

VN-RAG-018 · Câu hỏi thường gặp

Đơn vị: BIDV. Ngày công bố: chưa xác minh. Nhóm: legitimate_workflow.

https://bidv.com.vn/smartbanking/faq/

VN-RAG-019 · Phòng tránh và báo cáo email giả mạo

Đơn vị: Google. Ngày công bố: chưa xác minh. Nhóm: mixed_guidance.

https://support.google.com/mail/answer/8253?hl=vi

VN-RAG-020 · Bật tính năng Xác minh 2 bước

Đơn vị: Google. Ngày công bố: chưa xác minh. Nhóm: legitimate_workflow.

https://support.google.com/accounts/answer/185839?hl=vi

VN-RAG-021 · Bảo vệ Tài khoản Google bị tấn công hoặc bị xâm nhập

Đơn vị: Google. Ngày công bố: chưa xác minh. Nhóm: incident_response.

https://support.google.com/accounts/answer/6294825?hl=vi

VN-RAG-022 · Trang Hoạt động gần đây là trang gì?

Đơn vị: Microsoft. Ngày công bố: chưa xác minh. Nhóm: legitimate_workflow.

https://support.microsoft.com/vi-vn/accounts-billing/security/what-is-the-recent-activity-page

VN-RAG-023 · Cách sử dụng quy trình xác minh hai bước cho tài khoản Microsoft của bạn

Đơn vị: Microsoft. Ngày công bố: chưa xác minh. Nhóm: legitimate_workflow.

https://support.microsoft.com/vi-vn/accounts-billing/security/how-to-use-two-step-verification-with-your-microsoft-account

VN-RAG-024 · CẬP NHẬT THÔNG TIN SINH TRẮC HỌC VÀ GIẤY TỜ TÙY THÂN CÒN HIỆU LỰC ĐỂ KHÔNG BỊ GIÁN ĐOẠN GIAO DỊCH

Đơn vị: Vietcombank. Ngày công bố: 2024-10-24. Nhóm: legitimate_workflow.

https://vietcombank.com.vn/vi-VN/KHCN/Truy-cap-nhanh/Tin-noi-bat/Articles/2024/10/24/STH-update-new

VN-RAG-025 · Chương trình học bổng Goertek năm 2027

Đơn vị: Trường Đại học Công nghệ - ĐHQGHN. Ngày công bố: 2026-08-11. Nhóm: legitimate_workflow.

https://uet.vnu.edu.vn/chuong-trinh-hoc-bong-goertek-nam-2027/

PHỤ LỤC C. BẢN ĐỒ BẰNG CHỨNG VÀ QUY ƯỚC

C.1. Hiện vật để kiểm tra số liệu

Tất cả đường dẫn sau là tương đối so với thư mục có run.py. Bản làm việc và gói bàn giao có thể chứa tệp chưa có trên GitHub. Không suy rằng một liên kết repository tự chứng minh mọi kết quả được nhắc trong báo cáo.

inference_XGBoost_d6_s42/config.json

Run, seed, feature_names, ngưỡng và thông tin validation.

reports/phishvn_official_v1/provenance.json

Archive, split, fingerprint và kiểm tra tính nhất quán.

reports/phishvn_official_v1/url_model_metrics.json

Chỉ số toàn bộ URL test, core, tier và nguồn.

reports/phishvn_official_v1/test_predictions.csv

Từng điểm URL và nhãn để tính lại ma trận.

reports/phishvn_official_v1/selected_ids.csv

Danh sách 100 URL được chọn cho so sánh LLM.

reports/phishvn_official_v1/summary.json

Chỉ số năm cấu hình, số thay đổi theo cặp, usage và timing.

reports/phishvn_official_v1/results.jsonl

Đầu vào và kết quả từng mẫu; không có API key.

reports/phishvn_official_v1/independent_metric_check.json

Kiểm chứng số đo độc lập.

reports/url_model_ablation_v1/

Kết quả 60 thông điệp mô phỏng, tách khỏi PhishVN.

knowledge/corpus_v1/documents.jsonl; sources.csv

Tóm lược và danh mục 25 nguồn.

knowledge/corpus_v1/manifest.json; validation.json

Hash theo giai đoạn và kiểm tra corpus.

deliverables/bao_cao_phishing_2026_10_26/evidence/

Số đo độ trễ mới, lỗi biên đã kiểm tra và hash đầu vào báo cáo.

C.2. Khóa định danh của lần thực nghiệm

Fingerprint: d3d1ee19f42b. Run model: XGBoost_d6_s42. Prompt: baseline-1.0. Seed chọn mẫu: 20261026. Snapshot RAG: corpus_v1, indexed=false. Ngưỡng đã chọn trên validation; báo cáo không thay đổi ngưỡng để tạo lại kết quả tốt hơn trên test.

SHA-256 archive PhishVN:

```
308351e9d0c0fca13a81f2f63524a7dee08ccba6c775848d125b3da5525d0ab5
```

C.3. Phân biệt kết quả, mục tiêu và điều chưa biết

Kết quả đã đo: số URL, ma trận, chỉ số, usage, thời gian từ tệp và phép đo cục bộ. Mục tiêu chưa đo: F1 trên 160 thông điệp, tác dụng RAG, Recall@3, rubric, chống injection và hiệu quả ngưỡng/fusion mới. Điều chưa xác minh: số dư thực tài khoản API, chính sách lưu dữ liệu cụ thể của tài khoản và khả năng ứng dụng trên mọi môi trường. Báo cáo dùng các nhãn này nhất quán, không điền số giả vào phần kế hoạch.